Implementation guide: corporate level

Oct 30, 2026

How to set up the organisation so that every product in the portfolio can meet Regulation (EU) 2024/2847 by 11 Dec 2027, with reporting live now. Built from the Commission FAQ and guidance, ENISA and BSI material, notified-body and consultancy practice, and the open-source ecosystem's own guidance; vendor and consultancy claims are labelled as such.

1. Purpose and how to use this guide

This guide tells an organisation how to set itself up so every product it sells can comply with the CRA by 11 Dec 2027. The knowledge base explains what Regulation (EU) 2024/2847 requires. This guide explains how to organise, decide, document and run compliance across a portfolio.

Who it is for

Reader	What to take from this guide
Executive sponsor	Decision rights, budget lines, board metrics (Sections 2, 11)
Compliance lead	Policy set, scope register, evidence system, market access (Sections 3, 4, 8, 10)
Product security officer	Assurance model, risk-acceptance rules, release gate (Sections 2, 5)
PSIRT lead	Reporting governance, awareness authority, drills (Section 7)
OSPO	Component intake, upstream duties, stewardship decisions (Section 6)
Procurement	Supplier clauses, questionnaires, evidence rights (Section 6)
Legal	DoC signature control, representation, steward determinations, records (Sections 2, 8, 10)

What it produces

The output is a governed, evidenced, repeatable product-compliance capability. Governed means every CRA decision has a named owner and a written basis. Evidenced means every claim in a declaration of conformity traces to a record in a system of record.

Repeatable means a new product, version or market enters an existing process instead of starting a project.

How it fits with the rest of the knowledge base

- The knowledge base sections hold the law and guidance by topic; this guide cross-refers to them by name.
- The Requirement checklists tab holds the per-item questions a product must answer; this guide says who answers them and where the answers live.
- The application-level guide applies the system to one product: corporate sets the system, application applies it per product.
- Where this guide and a knowledge base section differ, the section wins.

Two facts that change the sequencing

1. Art 14 reporting has applied since 11 Sep 2026 to every in-scope product, legacy products included (Art 69(3)). Reporting governance (Section 7) is therefore built first.
2. A Class I product cannot self-assess today. No harmonised standard is cited in the OJ, and no notified body was verifiably designated at checks to 8 Sep 2026. Market access (Section 10) therefore starts now, in parallel with engineering.

Everything else follows the phases in the knowledge base, Engineering compliance programme. Commission FAQ v1.4 and guidance C(2026) 5252 are non-binding and give no presumption of conformity.

2. Governance: roles, decision rights and cadence

Every CRA decision needs one accountable person, and three of them cannot wait for a committee. Those three are the Art 14 awareness declaration, the acceptance of residual product risk and the signature on the EU declaration of conformity. This section fixes who holds each decision, how often the governing bodies meet and how disputes escalate.

The role descriptions themselves are in the knowledge base, Engineering compliance programme (Roles table). This section adds the decision rights and the cadence around them.

RACI

R is responsible for the work, A is accountable for the outcome, C is consulted before the decision and I is informed after it. One A per row, always a named individual, never a team.

Decision	Executive sponsor	Compliance lead	Product security officer	PSIRT lead	Engineering lead	Legal	Procurement	Product management
Scope and classification decision per product (Arts 2-3, 7; IR 2025/2392)	I	A	C	I	R	C	I	R
Risk assessment sign-off (Art 13(2)-(4))	I	C	A	C	R	I	I	C
Release gate (Annex I Part I(2)(a); guidance paras 230-237)	I	I	A	C	R	I	I	C
Declaration of conformity signature (Art 28; Annex V)	A	R	C	I	C	C	I	I
Art 14 awareness decision (guidance para 213)	I	I	C	A	R	I	I	I
Notified-body relationship (Art 32; Annex VIII)	C	A	R	I	C	C	R	I
Supplier terms (Art 13(5); Art 23)	I	C	C	I	C	R	A	I
Support period and end-of-support decision (Art 13(8), (19))	I	C	C	C	C	C	I	A
Steward determination for published FOSS (Arts 3(14), 24)	I	C	C	I	R	A	I	C
Budget (Section 11)	A	R	C	C	C	I	C	C

Two rows deserve comment. Product management is accountable for the support period because Art 13(8) ties it to expected use time, a commercial judgement with engineering inputs. Legal is accountable for steward determinations because the per-project monetisation test in guidance C(2026) 5252 paras 69-84 is a legal reading of business facts.

Decision rights that must sit with named individuals

Decision	Holder	Deputy chain	Written rule
Declaring "awareness" of an actively exploited vulnerability or severe incident, including at 03:00 on a Sunday	PSIRT lead	Two named deputies on the on-call rota	Awareness is a "reasonable degree of certainty" after an immediate initial assessment (guidance para 213); no approval step may precede it
Submitting the 24-hour early warning	The on-call Primary or Secondary Assigned Representative	Any other registered Assigned Representative	Legal reviews the 72-hour and final reports, not the early warning
Signing the EU declaration of conformity	Executive sponsor, or a delegate named in a signed instrument	One named alternate	The signatory assumes responsibility for compliance (Art 28(4)); no delegation by email
Accepting residual product risk	Product security officer	Executive sponsor on appeal	Judged against "appropriate level of cybersecurity"; cost, appetite or commercial strategy are "not relevant" (guidance paras 156-163)
Approving a non-applicable Annex I Part I(2) item	Product security officer	None	Justification recorded in the risk assessment (Art 13(3)-(4); Recital 55)
Blocking a release	Product security officer	Executive sponsor	Release-blocking authority is written into the sponsor's mandate

Decision	Holder	Deputy chain	Written rule
Choosing the main-establishment Member State and coordinator CSIRT	Compliance lead with legal	None	Decided and recorded before any incident (Art 14(7)); see the knowledge base, Reporting obligations

The residual-risk rule needs emphasis because it breaks enterprise habit. Most risk frameworks let a risk owner accept a risk above appetite with a business case. Guidance paras 156-163 say that for product risk "internal risk tolerance, commercial strategy or mere cost considerations" do not count.

If a risk cannot be addressed, the design, functionality or intended purpose may have to change instead. Section 5 explains how to carry this into the enterprise risk framework.

Making the DoC signature a controlled authority

1. Record the signing authority in a board or executive-committee instrument naming the signatory, alternate and scope (product families, markets).
2. Require a completed pre-signature checklist. It covers the Annex VII file, the assessment record or certificate, the signed risk assessment, the release gate and the Annex II information.
3. Make the compliance lead counter-sign the checklist, so the sponsor signs on evidence they did not assemble.
4. Log every signature in the system of record (Section 8) with the DoC id, product versions covered and the checklist reference.
5. Review the authority annually and on any change of signatory. An incorrect or absent DoC is a formal non-compliance under Art 58.

Commission FAQ v1.4 Section 6.8 says a DoC cannot be signed without a positive conformity assessment. It adds that a new version "might need a new declaration". The checklist step above is where both are enforced.

Steering cadence

Forum	Frequency	Chair	Standing agenda	Decisions taken
PSIRT review	Weekly, plus ad hoc on any awareness declaration	PSIRT lead	Open vulnerability cases, reporting clocks, upstream reports owed, advisory backlog, on-call rota	Case closure, disclosure timing, Art 14(8) user notification
Programme board	Monthly	Compliance lead; executive sponsor attends	Scope register changes, classification decisions, risk assessments awaiting sign-off, technical-file completeness, notified-body status, KPIs (Section 11)	Wave priorities, budget drawdown, escalations
Standards and guidance review	Quarterly	Compliance lead	OJ citations, FAQ and guidance versions, ENISA and BSI publications, delegated and implementing acts, Member State enforcement laws, notified-body designations	Re-mapping decisions, policy updates
Executive review	Quarterly, aligned to board reporting	Executive sponsor	Portfolio status, residual-risk appeals, DoC pipeline, exposure under Art 64	Risk appeals, resourcing

The quarterly review exists because the authority stack moves. The Commission FAQ reached v1.4 within nine months, and the Art 26 guidance of 27 Jul 2026 formally remains a draft. The knowledge base, Open questions and watchlist, lists the dates to track.

Escalation paths

- Engineering disagrees with a release block: engineering lead to product security officer, then to the executive sponsor within two working days. The block stands until overturned in writing.
- Residual risk the product security officer will not accept: to the executive sponsor. The sponsor may only overturn with a written basis that is not cost or appetite (guidance paras 156-163).
- Dispute over classification or scope: compliance lead to legal; if unresolved, the stricter reading applies until the programme board decides.
- Awareness contested after the fact: never reopened to delay a filing; reviewed at the next PSIRT review and the lesson recorded.
- Supplier refuses CRA clauses: procurement to compliance lead; the component enters the intake gate (Section 6) as high risk with a documented exit plan.
- Notified-body slot at risk: compliance lead to programme board; fallback is a second pre-contracted body (Section 10).

Governance checklist

- [ ] RACI adopted and published, with one named individual per A
- [ ] Awareness authority and deputy chain written into the PSIRT runbook and the on-call rota
- [ ] DoC signing instrument executed; pre-signature checklist and counter-signature in use
- [ ] Residual-risk rule from guidance paras 156-163 written into the product-risk category (Section 5)
- [ ] Four forums scheduled with chairs and standing agendas
- [ ] Escalation paths published with working-day limits
- [ ] Annual review date set for the RACI, signing authority and on-call roster

3. The policy set

Seven policies carry the CRA into the organisation, and two of them are legal requirements rather than good practice. Annex I Part II point 5 requires a coordinated vulnerability disclosure (CVD) policy of every manufacturer. Art 24(1) requires a documented, verifiable cybersecurity policy of every open-source software steward.

The other five are the organisation's way of making the remaining obligations repeatable. Each policy names an owner, maps to articles and annex points, and borrows from a published template where one exists. None of the templates gives presumption of

conformity.

The seven policies

Policy	Mandatory contents mapped to articles and annex points	Owner	Template or reference
Product cybersecurity (secure by design and default)	Risk assessment per product and version, maintained through the support period (Art 13(2)-(4), (7)); Annex I Part I(1) and per-item applicability for (2)(a)-(m) with justification (Art 13(3)-(4)); release gate and "no known exploitable vulnerabilities" decision (Part I(2)(a)); secure defaults (Part I(2)(b)); remote data processing in scope (Art 3(2)); substantial-modification test per release (Art 3(30); guidance paras 104-124)	Product security officer	BSI TR-03183-1 v1.0.0 Sections 5-6; ENISA Playbook v1.0; OpenChain CRA checklist (community draft)

Policy	Mandatory contents mapped to articles and annex points	Owner	Template or reference
Vulnerability handling and coordinated disclosure	Component and vulnerability documentation and SBOM (Part II(1)); remediation without delay and separation of security from functionality updates (Part II(2)); regular tests and reviews (Part II(3)); public disclosure of fixed vulnerabilities (Part II(4)); CVD policy (Part II(5)); information sharing and contact address (Part II(6); Art 13(17)); secure update distribution (Part II(7)-(8)); upstream reporting and fix sharing (Art 13(6))	PSIRT lead	BSI TR-03183-3 v1.0.0; ENISA SME Vulnerability Kit (Oct 2026, consultation draft); FIRST PSIRT Services Framework v1.1
Support period and end of support	Determination criteria and evidence (Art 13(8); Annex VII point 4); 10-year update availability (Art 13(9)); latest-version rule and archives (Art 13(10)-(11)); end date at purchase and end-of-support notification (Art 13(19)); Annex II point 7	Product management	Guidance C(2026) 5252 Section 5, paras 125-135; OpenChain CRA checklist Section 6

Policy	Mandatory contents mapped to articles and annex points	Owner	Template or reference
Third-party and open-source component due diligence	Due diligence on all components including unplaced FOSS (Art 13(5); Recital 34; guidance paras 167-173); documentation of third-party information (Art 13(7)); upstream reporting (Art 13(6); guidance paras 222-229); SBOM inclusion (Part II(1)); traceability records (Art 23)	Engineering lead or OSPO, with procurement	Commission FAQ v1.4 due-diligence actions; ENISA SBOM advisory v1.10; VDMA supplier self-disclosure guideline (trade association); OpenChain CRA checklist
CRA reporting	Triggers and awareness test (Art 3(42); Art 14(1), (3), (5); guidance paras 211-218); clocks and content (Art 14(2), (4), (6)); routing to the coordinator CSIRT via the SRP (Art 14(7)); user notification (Art 14(8)); legacy products (Art 69(3)); records	PSIRT lead	ENISA SRP glossary and AR manual v1.2; BSI TR-03183-3; OpenChain CRA checklist Section 4.5

Policy	Mandatory contents mapped to articles and annex points	Owner	Template or reference
Documentation and records	Technical documentation before placing on the market and kept current (Art 31; Annex VII); DoC (Art 28; Annexes V-VI); retention of 10 years or the support period (Arts 13(13), 13(18), 18(3), 19); reasoned requests in a language the authority understands (Art 13(22)); traceability (Art 23)	Compliance lead	BSI TR-03183-1 Section 4.8 report structure; Commission FAQ v1.4 Sections 6.6-6.8
Open-source stewardship (where the organisation publishes open source)	Documented, verifiable cybersecurity policy for each stewarded project (Art 24(1)); cooperation with authorities and supply on reasoned request (Art 24(2)); reporting to the extent involved (Art 24(3); guidance paras 79-82); per-project steward or manufacturer determination (guidance paras 69-74, 84)	Legal, with the OSPO	ORC WG steward white paper V1.0 (Jan 2026, "not legal guidance"); LF Stewards Playbook; OSPS Baseline

Legal status of each policy

Policy	Status	Basis
Vulnerability handling and coordinated disclosure	Legally required: the CVD policy is Annex I Part II point 5; the process behind it is Art 13(8) fourth subparagraph	Must exist by 11 Dec 2027 for every product placed from then; Annex VII point 2(b) puts it in the technical file
Open-source stewardship	Legally required where the organisation is a steward (Art 24(1)); applies from 11 Dec 2027	No fines for stewards (Art 64(10)(b)), but corrective action under Art 52(3)
Product cybersecurity	Good practice; the obligations are real but no policy document is prescribed	Module H assessors expect written policies (Annex VIII pt 3.2)
Support period and end of support	Good practice; the determination evidence is required (Annex VII point 4)	A policy makes per-product decisions consistent
Third-party and open-source component due diligence	Good practice; Art 13(5) is an obligation of conduct, not a document	Due-diligence records are the evidence
CRA reporting	Good practice; Art 14 prescribes the duty, not a policy	A written awareness rule protects the 24-hour clock
Documentation and records	Good practice; Arts 13(13) and 31 prescribe the records	A policy stops evidence drifting into mailboxes

What each policy must say

Product cybersecurity

- Every product and every substantially modified version has a risk assessment before placing on the market. It is kept current through the support period (Art 13(2)-(4), (7)).
- The risk assessment states for each Annex I Part I(2)(a)-(m) item whether it applies and how it is implemented. Any non-applicable item carries a written justification (Art 13(3)-(4)).

- Residual risk is judged against "appropriate level of cybersecurity based on the risks". Cost, appetite or commercial strategy cannot justify unaddressed risk (guidance paras 156-163).
- No product is released with a known exploitable vulnerability; "known" includes EUVD and other databases, private disclosure and reliable media (guidance paras 230-237).
- Secure defaults, reset to original state, no default credentials and default-deny exposure are acceptance criteria (Part I(2)(b)).
- Remote data processing under the manufacturer's responsibility and needed for a product function is inside the assessed boundary (Art 3(2); guidance Section 8).
- Every release passes a security-delta assessment against the four-question substantial-modification test (guidance paras 104-124).
- Threat modelling follows a documented method and precedes development; TR-03183-1 and the ENISA Playbook are the reference methods.

Vulnerability handling and coordinated disclosure

- The public contact: a single point of contact that is not automated-only (Art 13(17)). Add a security.txt per RFC 9116 and an anonymous web form (TR-03183-3).
- Scope: which products, versions and services the policy covers, including out-of-support versions still reportable under Art 14.
- Safe harbour: assurances of confidentiality, no disclosure of reporter data, no legal action and no NDA requirement for good-faith research (TR-03183-3 Section 4.4).
- Timelines: acknowledgement and detailed feedback targets. BSI gives 5 and 10 working days; draft prEN 40000-1-3 caps acknowledgement at 7 calendar days (ENISA kit footnote, draft standard).
- What reporters can expect: triage, status updates, credit and a default disclosure window. BSI's model is 90 days, extendable once by 90 days with the national CSIRT.
- Every report is checked for active exploitation, because that check starts the Art 14 clock (ENISA kit "common mistakes").
- Security updates are released separately from functionality updates where technically feasible, with the Commission's exceptions documented (FAQ Section 4.3).
- Fixed vulnerabilities are disclosed publicly with affected versions and remediation, machine-readable where appropriate (Part II(4); CSAF recommended by BSI).

Support period and end of support

- Five years is a floor, not the default; expected use time governs (Art 13(8); guidance paras 125-128).
- The period is set per product and per substantially modified software version using the Art 13(8) criteria. The evidence goes in Annex VII point 4.

- A substantial modification triggers reassessment but does not reset the period by itself (guidance paras 132-135).
- The end date, at least month and year, is shown at purchase and in the Annex II information (Art 13(19); Annex II point 7). It also goes on the product or packaging where applicable.
- Users receive an end-of-support notification where technically feasible, and a legacy-version owner is named (Art 13(19); OpenChain CRA checklist).
- Security updates stay available for at least 10 years or the remainder of the support period (Art 13(9)).
- Remediating only the latest version is allowed only where users can upgrade free of charge without "additional costs" (Art 13(10); guidance paras 129-131).
- Reporting under Art 14 continues after the end of support; vulnerability handling does not (guidance para 210).

Third-party and open-source component due diligence

- Every component passes an intake gate that records the need, the evidence and the decision (Art 13(5); guidance paras 167-173; Section 6).
- The level of diligence matches the component's risk; Recital 34 and the FAQ list the actions to choose from.
- Unplaced FOSS gets the same gate; the project's own status under the CRA is irrelevant to the integrator's duty (guidance paras 86-88).
- Vulnerabilities found in a component are reported to its maintainer through the maintainer's channel (Art 13(6)). Fixes are shared in licence-compatible, machine-readable form (guidance paras 222-229).
- Suppliers of commercial components must accept the contract clauses in Section 6, or the component is treated as unsupported.
- Every component appears in the release SBOM to at least top-level dependencies (Part II(1)), with BSI TR-03183-2 depth as the target.
- Supply-chain records are kept for 10 years up and down the chain (Art 23).

CRA reporting

- The PSIRT lead or a named deputy declares awareness at "reasonable degree of certainty" after immediate initial assessment (guidance para 213). No approval step precedes it.
- Not reportable: good-faith findings without exploitation evidence, and component CVEs not reachable or exploited in the product (FAQ 5.2, 5.4; guidance para 218). These are still documented.
- The early warning is filed within 24 hours of awareness and the notification within 72 hours of the same awareness. The final report follows Art 14(2)(c) or 14(4)(c) timing.

- Legal reviews the 72-hour and final reports, not the early warning.
- The main-establishment Member State and coordinator CSIRT are decided in advance (Art 14(7)); a wrong choice "may invalidate the notification" (ENISA SRP FAQ 18).
- Users are informed in a timely manner, in a risk-based and proportionate way (Art 14(8); guidance paras 219-221).
- Legacy products placed before 11 Dec 2027 stay in the reportable inventory (Art 69(3)).
- UTC timestamps for first signal, awareness, escalation and each submission are recorded in the case file.

Documentation and records

- The Annex VII technical file exists before placing on the market and is kept current at least through the support period (Art 31(2)).
- Each product version has its own file state, with the SBOM, risk assessment, test reports and DoC version-linked to the release.
- Retention is 10 years from placing on the market or the support period, whichever is longer (Art 13(13), (18); Annex VIII).
- Documents can be supplied on reasoned request in a language the authority easily understands (Art 13(22)). The internal target is 10 working days.
- Evidence lives in the system of record (Section 8), not in mailboxes or spreadsheets.
- Every answer to an authority is logged with author, recipient and date, because misleading information is fined under Art 64(4).

Open-source stewardship

- Each published open-source project has a written steward or manufacturer determination, reviewed when monetisation changes (guidance paras 69-74, 84).
- The policy fosters secure development and effective vulnerability handling by the project's developers (Art 24(1)).
- It covers documenting, addressing and remediating vulnerabilities, and sharing information on discovered vulnerabilities within the community (Art 24(1)).
- It promotes voluntary reporting under Art 15 (Art 24(1)).
- It states the type of support provided, because non-technical, infrastructure and engineering support carry different Art 14 duties (guidance paras 79-82).
- It is "verifiable": evidence lives in version-controlled files such as SECURITY.md, advisories and CVE or EUVD entries (ORC WG white paper V1.0).
- It can be supplied to a market surveillance authority on reasoned request in a language it understands (Art 24(2)).

Policy checklist

- [ ] Seven policies drafted, each with an owner from the RACI in Section 2
- [ ] CVD policy published at the URL named in security.txt and the Annex II information
- [ ] Steward policies published for every project with a steward determination
- [ ] Each policy cites the guidance version it relies on and has a review trigger in the quarterly standards review
- [ ] Policies cross-reference the Requirement checklists tab for the per-product questions they govern

4. Portfolio inventory and scope register

The scope register is the record every other CRA artefact hangs off, and the first pass almost always undercounts. One consultancy reports inventories growing five-fold once versions, OEM-branded units, companion apps and cloud functions are counted (OmniTrust, consultancy claim). A register that lists only marketed SKUs will leave products unassessed on 11 Dec 2027.

This section gives the data model, the build method, the decision-record format and the change triggers. The scope tests themselves are in the knowledge base, Scope: what the CRA covers, and the class tests in Product classification.

Data model

One row per product version, grouped into families and lineages. The "why" column says which obligation the field serves; the source article is where the obligation sits in Regulation (EU) 2024/2847.

Field	Why	Source article or guidance
Product id	Stable key joining the register to the technical file, SBOMs, DoCs and case files	Art 13(15) type, batch or serial identification
SKU and version lineage	Obligations attach per unit at placing; for software, all copies of a version are placed at its first offering, and later versions keep that date unless they are a substantial modification. Record every version and whether it is a new placing	Art 3(21)-(22); guidance paras 13-15, Example 2

Field	Why	Source article or guidance
Hardware, software and RDPS boundary	Annex I reaches manufacturer-built back-ends needed for a product function; the boundary decides what the risk assessment covers	Art 3(2); Recitals 11-12; guidance Section 8
Companion apps	A mobile or desktop app supplied with the product is itself a product with digital elements, with its own version lineage	Art 3(1); guidance paras 20-21
Variants and families	A family sharing architecture, security-relevant design, intended purpose and risks may share one risk assessment, one technical file and one DoC	Guidance paras 174-177
Markets	Which Member States the product is made available in; drives the DoC language rule and which MSAs can ask	Art 28(2); Art 52(1)
Role per market	Manufacturer, importer, distributor or authorised representative; own-brand resale or substantial modification makes you manufacturer	Arts 3(13)-(17), 18-22
Placing date per version	Units placed before 11 Dec 2027 are caught only on substantial modification; Art 14 applies regardless	Art 69(2)-(3)
Scope decision and basis	In, out or RDPS, with the test applied and the guidance paragraphs relied on	Art 2(1); guidance Section 2
Class and core-functionality rationale	Default, Class I, Class II or critical, judged on core functionality against the technical descriptions	Art 7; Annexes III-IV; Implementing Regulation (EU) 2025/2392; guidance Section 6

Field	Why	Source article or guidance
Conformity route	Module A, B+C, H or a certificate; Class I needs B+C or H while no harmonised standard is cited	Art 32; Annex VIII; guidance paras 148-151
Support period and end date	Declared per product and per substantially modified software version; month and year shown at purchase	Art 13(8), (19); guidance Section 5
Notified body	Which body, which module, certificate id and surveillance dates	Art 32; Annex VIII Modules B and H
DoC id	Which declaration covers this version, who signed it and when	Art 28; Annex V; Section 2
Art 14 coordinator CSIRT	The Member State and CSIRT this product's reports route to	Art 14(7)
Legacy flag	Placed before 11 Dec 2027 and not substantially modified since: reportable, not otherwise regulated	Art 69(2)-(3); FAQ Section 5.3
Owner	The product manager and engineering lead accountable for keeping the row true	Section 2 RACI
Last reviewed	Date and reviewer of the last scope and class check	Programme board cadence

Two fields need discipline. The RDPS boundary field must name the functions the product cannot perform without each back-end, the three-element test in guidance Section 8. The class field must record the one core functionality, since separately sold modules are separate products (guidance Section 6).

How to build it

1. Start from the release system: every tagged release, firmware image, installer and app-store build of the last support period, not the current catalogue.
2. Join the commercial systems: SKUs, price lists, OEM and white-label agreements, reseller contracts and bundles, so own-brand resale and rebranding surface (Art 21).

3. Reconcile with cloud and app stores: list every back-end a product talks to and every app-store listing. Classify each as RDPS, third-party component or out of scope (guidance Section 8).
4. Add acquisitions and legacy lines, where documentation often has to be recreated and classifications are inconsistent (OmniTrust, consultancy).
5. Run the scope test on each row with a cross-functional group: product, engineering, security, legal and quality. Consultancy practice recommends this mix.
6. Record a decision record for each product (below) before the class test, because class depends on the scope boundary.
7. Fix the economic-operator role per market and flag any market where there is no EU importer or representative (see Section 10).
8. Baseline the register and put it under change control, with the triggers below.

Expect the first count to be wrong. Plan a second reconciliation pass after the first release-gate run, when engineering discovers the components and services the register missed.

Decision records

Each product gets one scope and classification decision record, held in the system of record (Section 8) and referenced from the register. The record is what a market surveillance authority or notified body will read first.

Element	Content
Decision	In scope, out of scope, or RDPS of a named product; class and conformity route
Basis	The three cumulative scope conditions of Art 2(1) applied to this product; the core-functionality test; the exclusion considered (Art 2(2)-(7))
Guidance relied on	Paragraph and example numbers from guidance C(2026) 5252 and section numbers from FAQ v1.4, with the versions used
Who	The compliance lead as accountable, the product and engineering leads as responsible, legal as consulted (Section 2 RACI)
Date	Decision date and the date of the guidance versions relied on

Element	Content
Review trigger	Which of the change triggers below reopens the record
Open points	Anything unresolved, such as dual licensing or paid hosting where the guidance is silent

Because the guidance is non-binding and still formally a draft, the record must say which version it relied on. When a later FAQ version or a cited harmonised standard changes the answer, the record is superseded, not edited.

The version placing rule for software

For standalone software, the register records every version and whether it is a new placing. Guidance paras 13-15 deem all copies placed at the first offering; later versions keep that date unless they are a substantial modification (Example 2).

A version that is a substantial modification is a new placing and needs its own declared support period (guidance paras 104-124, 128). It may also need its own DoC (FAQ Section 6.8).

The register therefore needs the release engineering feed, not a quarterly product list. The release gate (knowledge base, Engineering compliance programme) is where the security-delta assessment decides whether a release opens a new lineage row.

Ownership and change triggers

The compliance lead owns the register; product management owns each row's commercial fields and engineering owns the technical ones. The register is reviewed at the monthly programme board (Section 2).

Trigger	What reopens	Who raises it
New SKU, bundle or OEM agreement	Scope decision, role per market, family membership	Product management
New market or sales channel, including a marketplace or direct-to-consumer site	Role per market, importer or representative, DoC language, CSIRT routing for non-EU manufacturers	Product management with legal

Trigger	What reopens	Who raises it
Substantial modification found at the release gate	New version row, new placing date, support-period reassessment, DoC review, classification re-check	Engineering lead
Module unbundling or a function sold separately	New product with its own core functionality and class	Product management
New or changed back-end, or a third-party SaaS integrated	RDPS boundary, component due diligence	Engineering lead
Acquisition or divestment	Whole register section; roles and brands	Legal
New guidance version, OJ citation or implementing act	Decision records relying on the changed text	Compliance lead (quarterly review)
End of support reached	Legacy flag, reportable-only status	Product management

Register checklist

- [ ] Every release of the last support period is a row, including companion apps and app-store builds
- [ ] Every row has an RDPS boundary statement naming the dependent functions
- [ ] Every row has a role per market and a flagged gap where no EU operator exists
- [ ] Every product has a dated decision record naming the guidance paragraphs relied on
- [ ] Every Class I and II row has a route and a notified-body plan (Section 10)
- [ ] Legacy rows carry the Art 14 coordinator CSIRT, because they remain reportable
- [ ] Change triggers are wired to the release gate and the commercial systems, not to a calendar

5. Risk and assurance model

Product risk under the CRA is not enterprise risk, and the assurance model must say so in writing. The Art 13 risk assessment is judged against an "appropriate level of cybersecurity based on the risks" (Annex I Part I(1)). Guidance C(2026) 5252 paras 156-163 add that "internal risk tolerance, commercial strategy or mere cost considerations are not relevant" to that judgement.

This section sets out three lines of assurance and the product-risk category the enterprise framework needs. It then covers applicability sign-off and how an ISO/IEC 27001 ISMS can carry Module H. It closes with what auditors expect and what existing certificates prove.

Three lines of assurance

Line	Who	What they do	Evidence produced	Independence
1. Engineering self-assessment	Product team, engineering lead	Threat model, risk assessment, Annex I applicability matrix, controls, tests, SBOM, release-gate record	Risk assessment with decision trail; release security gate record; test reports	None; the team that builds also assesses
2. Product security review	Product security officer and reviewers outside the delivering team	Challenge the threat model, verify the applicability justifications, check the release-gate evidence, sign off residual risk	Signed risk assessment; review notes; accepted and rejected residual risks	Reviewer has no delivery role on the product
3. Internal audit or compliance sampling	Internal audit, or the compliance lead sampling across families	Test that lines 1 and 2 ran as written; sample technical files; check retention, system-of-record integrity and reasoned-request readiness	Audit reports to the programme board and executive review	Reports outside the product organisation

Line 2 is the one most organisations lack. Early adopters performed risk assessments but "could not show the decision trail" (OmniTrust, consultancy). The second line exists to make that trail visible before a notified body or authority asks for it.

Line 3 should sample, not re-perform. One technical file per product family per year, chosen by risk, shows the system works and feeds the KPIs in Section 11.

The product-risk rule

The enterprise risk framework needs a product-risk category with its own acceptance rules, because the usual rules do not apply.

Enterprise risk habit	Product-risk rule under the CRA	Source
Risk above appetite may be accepted with a business case	Residual risk is judged against the appropriate level of cybersecurity for the product; appetite is irrelevant	Annex I Part I(1); guidance paras 156-163
Cost of control is weighed against likelihood and impact	Cost alone cannot justify leaving a risk unaddressed; if a risk cannot be addressed, design or intended purpose may have to change	Guidance paras 156-163
Risk may be transferred to the customer by contract or warning	Risk cannot be transferred to users to compensate for design shortcomings; user information treats residual risk, not design gaps	Guidance paras 156-163; Recital 55; Annex II point 5
Annual risk review	Update on security-relevant release, newly known vulnerability or new threat; maintained through the support period	Art 13(2)-(4), (7); BSI TR-03183-1 v1.0.0 RH_UPD.1
Risk owner is any manager	Residual product risk is accepted by the product security officer; appeal to the executive sponsor on a non-cost basis only	Section 2

Write the category into the risk policy, with its own register, acceptance authority and escalation. Tailor-made products are the one place contract can narrow obligations, and only for secure-by-default and free updates (FAQ Section 4.2). Everything else stays with the manufacturer whatever the contract says.

Per-item applicability sign-off

Art 13(3) requires the risk assessment to state whether and how each Annex I Part I(2)(a)-(m) item applies and how it is implemented. Art 13(4) and Recital 55 require a justification for each item marked not applicable. Part II items are not subject to this test; all eight apply throughout the support period (FAQ Section 4.1).

1. Line 1 completes the applicability matrix as a design input, before development, and refreshes it at each release gate.
2. Each "not applicable" entry carries a reason tied to intended purpose or interoperability constraints. It also names the compensating measure, such as limiting intended purpose to trusted environments or informing users (FAQ Section 4.1).
3. Line 2 signs the matrix as a whole; a matrix cannot be signed with a blank justification.
4. The signed matrix is filed in the technical documentation under Annex VII point 3 and referenced from the DoC pre-signature checklist (Section 2).
5. Line 3 samples justifications against the knowledge base, Annex I Part I: essential requirements for product properties, and the Requirement checklists tab.

Items (2)(c) automatic updates and (2)(m) data transfer carry a second "where applicable". Recital 56 gives carve-outs for components and professional or industrial environments. Those are the most common non-applicable entries and the most scrutinised.

Extending an ISO/IEC 27001 ISMS to carry Module H

Non-binding BSI TR-03183-H v1.1.0 (30 May 2026) shows how an ISO/IEC 27001 ISMS can be extended to design, development, production and vulnerability handling. It is not a new management-system standard and gives no presumption of conformity. BSI's accreditation programme for Module H bodies builds on ISO/IEC 17021-1 with TR-03183-H, so it is the reference for German-notified bodies at least.

TR-03183-H refines	Clause or control	What changes
ISMS scope and context	ISO/IEC 27001 clauses 4.2, 4.3	Interested parties include users, authorities and notified bodies; scope must include the products, their RDPS, build pipelines and update infrastructure

TR-03183-H refines	Clause or control	What changes
Policy and risk	Clauses 5.2, 6.1.2, 6.1.3, 6.3	Product-risk assessment per TR-03183-1 sits inside the ISMS risk process; the product-risk rule above is written into 6.1.3 acceptance criteria
Communication and documented information	Clauses 7.4, 7.5.1	Annex II user information, advisories and Art 14 reports are controlled communications; Annex VII files are controlled documents
Operational planning	Clause 8.1	Design, development, production and post-market updates run as controlled processes; updates are "changes to the product"
Threat intelligence and project security	ISO/IEC 27002 controls 5.7, 5.8	Threat feeds drive risk-assessment updates; security is planned into every product project
Technical vulnerabilities	Control 8.8	Covers product vulnerabilities, not only infrastructure; links to Annex I Part II
Secure development, testing, change	Controls 8.25, 8.29, 8.32	SDLC, security testing and change management are specified to CRA Part II expectations
Quality additions	ISO 9001 elements	Production, final inspection and testing requirements that ISO/IEC 27001 does not carry

Two warnings. Module H "is not just a quality system certification" (TR-03183-H Appendix B). The body also reviews one technical file per product category, with a product-field assessor on the team (Annex VIII Module H pts 3.1, 3.3).

An ISMS whose scope excludes firmware, build pipelines or update infrastructure cannot carry Module H, whatever its certificate says.

Choosing Module H over B+C

Factor	Favours Module H	Favours Module B+C
Portfolio size	Many product types; FAQ Section 6.3 describes H as suited to many types or frequent updates	Few, stable product types
Change rate	Frequent substantial modifications; scope extensions go to the same body as a "more streamlined process" (FAQ Section 6.3)	Rare substantial modifications; each needs a new type examination
Existing systems	ISO/IEC 27001 ISMS already covering product engineering	No ISMS, or one scoped to IT only
Marking	Notified-body number follows the CE mark (Art 30(4); Module H pt 5.1)	No body number on the mark; certificate referenced in the DoC (Annex V item 7)
Cost (vendor estimates, unverified)	First engagement EUR 80,000-150,000 with surveillance every 1-2 years; break-even around four products (CRA Decoded, commentary)	EUR 20,000-60,000 per type examination (same source)
Surveillance	Periodic audits of the quality system plus site access (Module H pt 4)	Periodic audits of vulnerability handling under Module B pt 8
Availability	Needs a body accredited to EN ISO/IEC 17021-1 for the CRA; none designated as of checks to 8 Sep 2026	Needs a body accredited to EN ISO/IEC 17065; same position

Whichever route is chosen, keep the Module A paperwork complete regardless (knowledge base, Engineering compliance programme). A Module A record is also the fallback if an OJ citation arrives before a Class I product is placed on the market.

Evidence auditors expect

Notified bodies and labs have not published checklists, but their service pages converge (Brightsight, TÜViT, Applus+, UL, all vendor statements).

- Technical documentation structured to Annex VII, with the risk assessment and its applicability matrix at the centre.
- A threat model with a data-flow diagram and an asset list in three categories: data, functional and security (TR-03183-1).
- Decision records for each applicability path, in the EN 18031 style of requirement, asset, interface, path, rationale and evidence (QIMA, vendor).
- An SBOM per release and a vulnerability-handling process with a live CVD policy.
- Test evidence tied to the release: SAST, DAST or fuzzing, penetration test, and re-tests on new threat input (guidance paras 238-240).
- Mapping from existing certifications (IEC 62443, EUCC, SESIP, EN 18031) to Annex I, with the gaps named.
- A supplier evidence trail: SBOMs, attestations and due-diligence records (UL, vendor).

Limits of existing certificates as CRA evidence

Certificate	What it does prove	What it does not prove	Source
ISO/IEC 27001	A management system exists and is audited	Product conformity; nothing unless the scope covers products, pipelines and update infrastructure; ISO 9000 alone does not satisfy Module H	FAQ Section 6.3; TR-03183-H
IEC 62443-4-1 and 4-2	A strong SDLC and component controls for industrial systems; covers 36 of 42 NIST SSDF tasks (ISAGCA)	Fixed reporting timelines, SBOM depth, public disclosure, user documentation; not expected to be cited in the OJ	JRC-ENISA mapping; IBF Solutions (consultancy)

Certificate	What it does prove	What it does not prove	Source
EN 18031-1/-2/-3	RED cybersecurity conformity for radio equipment placed to 10 Dec 2027	CRA conformity. Delegated Regulation (EU) 2026/339 repeals the RED act from 11 Dec 2027. Evidence is partly reusable but "does not replace" an EN 40000-1-4 assessment	Knowledge base, Interplay with other law, the Digital Omnibus and the UK position
EUCC or Common Criteria	Assurance against a protection profile; a "substantial" certificate may lift the third-party duty once an Art 27(9) delegated act names the scheme	CVD policy and free updates sit outside CC; RDPS unaddressed; the Art 27(9) act is planned for Q4 2026 and not adopted	ENISA EUCC-CRA study, Feb 2025; knowledge base, Standards and guidance map
Any draft EN 40000 or ETSI EN 304 6xx assessment	Evidence under Annex VII point 5 as a technical specification; reduces rework when cited	No presumption and no Module A eligibility for Class I until the OJ citation exists	Art 27; guidance paras 148-151

The common lesson from early adopters is that "being secure and being CRA-ready are not the same thing" (OmniTrust, consultancy). Certificates are inputs to the risk assessment and the standards list, never substitutes for the file.

Assurance checklist

- [ ] Product-risk category with its own acceptance rule and authority written into the enterprise risk framework
- [ ] Line 2 reviewers named per product family, with no delivery role on the products they review
- [ ] Applicability matrix template adopted with mandatory justification fields and sign-off
- [ ] ISMS scope statement checked against products, RDPS, pipelines and update infrastructure
- [ ] Module H or B+C decision recorded per family with the factors above

- [ ] Certificate-to-Annex I mapping produced for every existing certification, gaps listed
- [ ] Line 3 sampling plan agreed for the year, one file per family minimum

6. Supplier and open-source supply chain

Every component a product ships, bought or open source, is the manufacturer's responsibility, and Art 13(5) requires due diligence on all of them. The duty expressly includes free and open-source software never placed on the market. Integrating a component never transfers its compliance to the project or supplier (guidance C(2026) 5252 paras 86-88).

This section covers contract clauses, the supplier questionnaire, the component intake gate and the Art 13(6) upstream channel. It then covers the consumption policy and stewardship decisions for open source the organisation publishes. The legal analysis of who is a steward or manufacturer is in the knowledge base, Open-source software.

Supplier contract clauses

Procurement is accountable for these clauses (Section 2 RACI). Add them to master agreements for any supplier of software, firmware, hardware with firmware, SaaS integrated into a product, or development services.

Clause	What it must say	Why
Vulnerability notification	Supplier notifies the manufacturer of vulnerabilities in supplied components without undue delay, through a named channel, with affected versions and available fixes	Mirrors the Art 19(5) and 20(4) duties on importers and distributors; feeds the Art 14 awareness test
SBOM delivery	A machine-readable SBOM per delivered release in CycloneDX 1.6 or later or SPDX 3.0.1 or later, with the BSI TR-03183-2 v2.1.0 fields and declared known unknowns	Annex I Part II(1); the manufacturer's SBOM depth depends on supplier SBOMs; BSI allows referencing compliant component SBOMs
Support-period commitment	Declared support period per component version; notice before end of support; security updates for the period	Art 13(8) lets the manufacturer consider third-party core component support periods; an unsupported component must be replaced or patched by the manufacturer (FAQ Section 4)

Clause	What it must say	Why
Disclosure coordination	Embargo handling, joint advisory timing, CVE or EUVD assignment, and who speaks to users	Annex I Part II(4); Art 14(8); avoids a supplier advisory starting the manufacturer's clock unseen
Right to request evidence	Access to the supplier's DoC, technical documentation extracts, test reports and risk assessment on request, and on an authority's reasoned request	Art 13(5) due diligence evidence; Art 13(22) reasoned requests reach the manufacturer, not the supplier
End-of-life notice	Minimum notice before a component is withdrawn, with a last-time-buy or migration path	Art 13(8); Art 13(19) end-of-support promises to users depend on it
Cooperation with authorities	Supplier cooperates with the manufacturer's responses to market surveillance and notified bodies	Art 13(22); Annex VIII Module B pt 8 periodic audits
Traceability	Supplier identifies itself and its own suppliers of the component as required	Art 23 ten-year records
Fix sharing and licence	For open-source components supplied commercially, the supplier accepts upstream fix sharing in licence-compatible form	Art 13(6)
Cessation	Supplier notifies the manufacturer before ceasing operations and escrows or transfers what is needed to keep updating	Art 13(23) applies to the manufacturer, who must be able to keep its own promise

Clauses are not a substitute for diligence. Where a supplier refuses them, the component enters the intake gate as high risk with a documented exit plan (Section 2 escalation paths).

Supplier questionnaire outline

The VDMA supplier self-disclosure guideline (Jan 2026, trade association) is a usable model; VDMA also warns against over-engineering component testing. Adapt it to the following outline.

1. Identity and role: legal entity, EU establishment, whether the component is itself a CRA product and under which class.
2. Conformity: DoC and CE marking status, standards applied, notified body if any, Art 32(5) public documentation for open-source products.
3. Vulnerability handling: CVD policy URL, security.txt, PSIRT contact, acknowledgement and remediation targets, advisory format (CSAF preferred).
4. SBOM: format, version, depth, known unknowns, delivery mechanism per release.
5. Support: declared support period per version, update mechanism, end-of-life notice period.
6. Secure development: SDLC framework (IEC 62443-4-1, NIST SSDF, OWASP SAMM), testing cadence, signing and provenance practice.
7. Incident and reporting posture: how the supplier will notify the manufacturer of actively exploited vulnerabilities and severe incidents affecting the component.
8. Evidence available on request: risk assessment extracts, test reports, certifications with scope statements.

Score the answers against the component's risk, not against a fixed pass mark. Recital 34 says the level of diligence depends on the nature and level of cybersecurity risk of the component.

Component intake gate for open source

The gate records a decision for every new component and every major version. It satisfies Art 13(5) and the due-diligence actions in Commission FAQ v1.4. Those actions are composition analysis, sandboxing critical components, reviewing the component's SBOM and support period, assessing the maintainer's posture, and testing where risk warrants.

Gate question	Evidence recorded	Source
What does the product need from this component?	Functional and security need, trust boundary, data handled	Guidance paras 167-173: define the need, then verify
Is it maintained and released regularly?	Last release date, release cadence, responsiveness to issues, number of active maintainers	Recital 34 security-update history

Gate question	Evidence recorded	Source
What is its security posture?	OpenSSF Scorecard result, Best Practices Badge, SECURITY.md, published CVD channel	OpenSSF guidance; LF Stewards Playbook
What is the licence and is it compatible?	SPDX licence identifier, obligations, compatibility with fix sharing	Art 13(6) licence-compatible fixes
Any known vulnerabilities?	EUVD, NVD and OSV check at intake and continuously after	Recital 34; FAQ
Does it have a steward or a commercial vendor?	Steward determination from the project, vendor contract status	Guidance paras 69-78; Art 25 attestations once they exist
Does the SBOM depth reach it?	Whether it will appear in the release SBOM, with its own dependencies	Annex I Part II(1); TR-03183-2 depth rule
Fork and exit plan	What the organisation does if the maintainer disappears or the licence changes	Section below
Decision	Approved, approved with conditions, rejected; owner and date	Art 13(7) systematic documentation

Run the gate in the engineering workflow, not in procurement. A pull request that adds a dependency is the natural trigger. The gate record becomes part of the release-gate evidence (knowledge base, Engineering compliance programme).

The Art 13(6) upstream duty as an organisational channel

Art 13(6) requires the manufacturer to report a component vulnerability to the maintainer and to share any fix it develops, machine-readable where appropriate. Guidance Section 9.2.1 (paras 222-229) sets the practical rules, and ENISA's SME Vulnerability Kit lists failing to report upstream among its common mistakes.

Rule	Organisational consequence
Report only for the integrated version, through the maintainer's CVD channel	PSIRT or the OSPO owns upstream reporting; engineers do not file ad hoc issues

Rule	Organisational consequence
No duty where the maintainer is demonstrably already aware; check databases, advisories and issue trackers first	Triage includes a duplicate check and records it
Report vulnerabilities in the component itself, not integration-caused ones, though the latter is encouraged	Case file distinguishes component from integration defects
No duty where the component has no maintainer or the manufacturer no longer relies on the maintainer	The fork and exit plan takes over; inform the community where possible
Share fixes machine-readable, verifiable and licence-compatible, following maintainer guidelines	Legal pre-clears outbound contribution under the organisation's open-source contribution policy
No obligation that the fix be accepted or merged, and no obligation to accept the maintainer's fix	Keep the local patch under version control with its rationale

The duty applies from 11 Dec 2027, but a component vulnerability that is actively exploited in the product is reportable under Art 14 today. The PSIRT case file should therefore carry both the upstream report and the Art 14 decision.

Consumption policy

The policy says where code may come from and how it is pinned, verified and kept. It applies to developers, build systems and container images alike.

- Approved sources: named registries and mirrors only; direct downloads from arbitrary URLs are blocked in CI.
- Pinning: exact versions or commit hashes, including for CI actions and plugins. The March 2026 compromise of a scanner's GitHub Actions is the cautionary example (CRA Decoded, vendor-adjacent).
- Provenance: signed packages and attestations where available; SLSA-style build provenance for the organisation's own artefacts (OpenSSF guidance).
- Package-manager hygiene per ENISA's Technical Advisory for Secure Use of Package Managers (10 Mar 2026): package selection, integration, monitoring and dependency-vulnerability handling.
- Lock files committed and reviewed; dependency updates arrive as reviewed changes, not silent resolution.

- Private forks are a cost centre: LF's 2025 Open Source ROI survey (n=236), cited in its 2026 CRA report, puts the average at 86 forks and about 60 labour hours each per release. Fork only with an owner and a re-sync plan.
- Binary SCA on the shipped artefact, not only the manifest, because manifest-derived SBOMs miss embedded components (Finite State, vendor).

Stewardship decisions for open source the organisation publishes

Each published project gets a written determination, owned by legal with the OSPO (Section 2 RACI). The tests are in the knowledge base, Open-source software; the organisational rule is simple.

Situation	Role	What the organisation must do
Unmonetised project the organisation sustains, including code it also uses in its own products	Steward for the project (guidance paras 67-68, 75-78; Ex 25, 29)	Adopt an Art 24(1) policy for the project; cooperate with authorities (Art 24(2)); report under Art 24(3) to the extent of involvement; from 11 Dec 2027
Monetised project: paid binaries, paid updates, paid access to a supported version, donations that gate access	Manufacturer (guidance paras 51-57, 62)	Full CRA for the monetised edition; Art 32(5) lets an Annex III product self-assess if the Annex VII documentation is public
Open core	Manufacturer for the paid edition; steward for the community edition (paras 52-53)	Two determinations, two obligation sets; the register (Section 4) holds both
Contributions to projects the organisation does not control	Neither (Recital 18; paras 48-49, 85-86)	Contribution policy only; no CRA record needed beyond the intake gate

The OSPO's role is to maintain the project registry, run the Art 24(1) policies as living documents and own the upstream channel. The OSPO is never itself the regulated entity; the legal person is, project by project (knowledge base, Open-source software).

What an Art 24(1) policy must contain

Art 24(1) requires a documented, verifiable cybersecurity policy that fosters secure development and effective vulnerability handling by the project's developers. The ORC WG steward white paper V1.0 (Jan 2026, "not legal guidance") and the LF Stewards Playbook are the references. The ORC WG's formal steward policy specification (D4.4) is not shipped.

- Scope: the project and versions covered, and the type of support the steward provides, since obligations scale with it (guidance paras 79-82).
- Secure development expectations for contributors, with the OSPS Baseline as a control reference (41 requirements, three levels).
- Vulnerability handling: triage, prioritisation and remediation, and a channel for manufacturers to report (Art 24(1)).
- Information sharing with the community and with upstream and dependency maintainers (Art 24(1)).
- Promotion of voluntary reporting under Art 15 (Art 24(1)).
- Evidence kept in version-controlled files: SECURITY.md, advisories, CVE or EUVD entries (ORC WG white paper).
- Reporting arrangements for actively exploited vulnerabilities and severe incidents where engineering or infrastructure support is provided, including the SRP (Art 24(3)).
- User notification, preferably machine-readable such as CSAF (ORC WG white paper).
- The steward's contact and the legal entity that holds the role (LF One Pager).

When a maintainer disappears

1. Note that an unmaintained component removes the Art 13(6) upstream duty but not the duty to remediate (guidance paras 222-229; FAQ Section 4).
2. Decide between switching the component, disabling the function and patching autonomously; the FAQ names all three as remediation "via other means".
3. If patching, fork under a named owner, record the patch and rationale, and keep sharing fixes with the community where possible.
4. Update the SBOM to show the fork and its pedigree, and the risk assessment to show the new dependency.
5. Consider becoming the steward if the organisation will sustain the fork. Nobody can be forced into the role; a manufacturer may fork instead (FSFE, FOSDEM 2026 Q&A).
6. Reopen the intake gate record and the register row (Section 4).

Supply chain checklist

- [ ] Master agreements carry the ten clauses, or a documented exception per supplier

- [ ] Supplier questionnaire issued to every supplier of in-scope components; answers scored by component risk
- [ ] Intake gate wired to the dependency-change workflow, with records in the system of record
- [ ] Upstream reporting channel owned by PSIRT or the OSPO, with legal pre-clearance of fix sharing
- [ ] Consumption policy enforced in CI: approved sources, pinning, provenance checks, binary SCA
- [ ] Steward or manufacturer determination on file for every published project
- [ ] Art 24(1) policy published for every stewarded project before 11 Dec 2027
- [ ] Fork and exit plan recorded for every component rated high risk

7. Reporting and incident governance

Art 14 has applied since 11 Sep 2026, so this part of the programme must already work, legacy products included (Art 69(3)). The organisational design has to deliver an early warning within 24 hours of awareness on any day of the year. That rules out committee approval and legal review before the first filing.

This section covers the PSIRT, the awareness authority, platform governance and the choice of coordinator CSIRT. It then covers multi-regime coordination, user communication, drills and records. The platform mechanics, clocks and field sets are in the knowledge base, Reporting obligations (Article 14), and are not repeated here.

PSIRT distinct from the infrastructure CSIRT

BSI TR-03183-3 v1.0.0 requires at least two roles: a PSIRT for products and services, and a CSIRT for the organisation's own infrastructure. They may not be the same person unless the organisation is a microenterprise.

Art 14 is about the product's security. A ransomware incident at the manufacturer counts only if it compromises product security, such as update channels or signing keys (knowledge base, Reporting obligations).

Function	PSIRT	Infrastructure CSIRT
Object	Products, companion apps, RDPS, components shipped	Corporate networks, endpoints, SaaS the company uses
Intake	security.txt, psirt@ mailbox, anonymous web form, supplier notifications, telemetry	SOC alerts, IT service desk, threat intelligence

Function	PSIRT	Infrastructure CSIRT
Decision owned	Art 14 awareness; CVD disclosure timing; Art 14(8) user notification	Incident severity for the enterprise; NIS2 or GDPR notifications where applicable
Reporting channel	ENISA SRP to the coordinator CSIRT	National CSIRT or competent authority under NIS2; DPA under GDPR
Framework	FIRST PSIRT Services Framework v1.1	NIST SP 800-61 or equivalent
Shared	Threat intelligence, forensics, the multi-regime coordination cell below	

BSI recommends functional mailboxes with "psirt" and "csirt" prefixes and dedicated OpenPGP keys valid for five years or less. It also recommends daily automated reachability tests and enough staff "to compensate for any absences". A published CVD policy that nobody staffs is among the most reported pitfalls (ENISA SME Vulnerability Kit, Oct 2026 consultation draft).

24/7 on-call and the deputy chain

1. One PSIRT lead holds the awareness authority (Section 2); two named deputies hold it in the lead's absence, in a written order.
2. An on-call rota covers every hour; the person on call can reach an Assigned Representative with SRP access within one hour.
3. At least two Assigned Representatives are registered with EU Login, MFA and backup devices; the SRP has no corporate login, so each is personal.
4. The Primary and Secondary Assigned Representatives are themselves on the rota or reachable from it, because only they can file.
5. The rota, deputy chain and awareness authority are re-confirmed annually and on any personnel change (OpenChain CRA checklist Section 4.5, community draft).
6. Weekend coverage, loss of platform access and supplier delays are tested in drills (below).

The awareness decision and its written criteria

Guidance C(2026) 5252 para 213 requires an "immediate" assessment of a suspicious event. Awareness follows at "a reasonable degree of certainty". Suspicion starts triage; certainty starts the clock.

The criteria below are the PSIRT runbook's written test; they belong to the PSIRT lead and no one else.

Criterion	Reportable when	Not reportable when	Source
Actively exploited vulnerability	There is reliable evidence that a malicious actor exploited the vulnerability in a system without permission	A proof of concept or published exploit exists but no exploitation is observed	Art 3(42); BSI webinar examples via SCHUTZWERK (vendor, second-hand)
Research or bug-bounty finding	Only if exploitation evidence accompanies it	Good-faith finding without exploitation evidence; voluntary Art 15 report possible	FAQ 5.2; guidance para 218
Component vulnerability	The vulnerable code is present, reachable and exploited in this product	Code not present, not reachable or not exploited in the product; record the VEX justification	FAQ 5.4; guidance para 218
Severe incident	The incident affects, or could affect, the product's ability to protect sensitive data or functions, or leads to malicious code in the product or users' systems	An enterprise incident with no product-security effect	Art 14(5)(a)-(b)
Legacy product	Same tests; products placed before 11 Dec 2027 are reportable	Exploitation already known before 11 Sep 2026 is not reported retroactively	Art 69(3); guidance para 217
Out-of-support product	Same tests; reporting continues after end of support		Guidance para 210

Write a "not reportable" decision with the same rigour as a report (Clarysec, vendor). The case file records the awareness timestamp in UTC, the criterion applied and the evidence. For a component, a "not_affected" VEX statement with its justification is both the engineering artefact and the evidence that no report was due.

Where legal review sits

Legal reviews the 72-hour notification and the final report, never the 24-hour early warning. The early warning carries only the glossary's mandatory fields: type, title, summary, product and version, Member States and UTC awareness time. For incidents it adds whether malicious acts are suspected.

Nothing in it needs legal drafting, and waiting for approval is a named pitfall (Wavect, vendor).

Legal's job at 72 hours is the description of the vulnerability or incident, the measures taken and the user-facing wording. At the final report it is severity, impact and the record that will be visible to market surveillance under Art 16(3). Legal also owns the "particularly exceptional circumstances" decision, which exists only on the actively-exploited-vulnerability 72-hour tab.

Platform governance

The SRP Assigned Representative is an individual with an EU Login, not the Art 18 authorised representative. The roster needs managing like any privileged access.

Item	Rule	Source
Accounts	Personal EU Login with MFA for each Assigned Representative; passkeys and backup MFA devices; no shared accounts	ENISA SRP FAQ 9; practitioner account via cyberresilienceact.eu
Roles	One Primary Assigned Representative; up to 20 Secondary Assigned Representatives invited by the Primary once verified; invitation links expire after 7 days	ENISA SRP FAQ 9; registration guidance
Who holds them	PSIRT lead and deputies as Primary and first Secondaries; compliance lead as a Secondary; no one outside the on-call chain	Section 2
Roster	Held in the system of record with name, role, EU Login identity, date granted, date reviewed	Section 8

Item	Rule	Source
Offboarding	Remove or replace a leaver's association on exit day; a Secondary may claim the Primary role subject to CSIRT approval, so plan the succession	ENISA SRP FAQ 9
Drafts	Drafts are visible only to the creating Assigned Representative, so the authoritative case record is internal, never the SRP	ENISA SRP FAQ; Section 8
Validation	The coordinator CSIRT validates the association in parallel; up to 20 notifications may be filed while pending	ENISA SRP FAQ 9
Help desk and fallbacks	cra-srp-helpdesk@enisa.europa.eu, national fallbacks and the coordinator CSIRT contact held offline	Knowledge base, Reporting obligations

ENISA advises registering only when a notification is needed, to limit CSIRT workload; practitioners advise pre-registering. The safer position is to create the EU Login accounts and pre-decide the coordinator CSIRT now. Validation does not block filing (knowledge base, Reporting obligations).

Choosing and documenting the coordinator CSIRT

Art 14(7) routes every report to the CSIRT designated as coordinator in the Member State of the manufacturer's main establishment. The main establishment is where decisions on product cybersecurity are predominantly taken, else the EU establishment with most employees. A manufacturer with no EU establishment uses the Member State of its authorised representative, then importer, then distributor, then most users.

1. Legal and the compliance lead decide the Member State and record the reasoning in a decision record (Section 4 format), before any incident.
2. The record names the coordinator CSIRT from ENISA's list of 4 Sep 2026 and its contact URL.
3. A group with several legal entities decides per manufacturer entity, because the SRP association is per manufacturer.
4. The decision is reviewed when product-security decision-making moves, on acquisition or restructuring, and at the quarterly review.

5. The reason this matters: a wrong choice "may invalidate the notification" (ENISA SRP FAQ 18).

The multi-regime coordination cell

One compromised product can start several clocks with several recipients, and nothing in force lets one filing discharge another (knowledge base, Reporting obligations). Organisations also under NIS2, GDPR or DORA need a standing coordination cell, convened by the PSIRT lead on any awareness declaration.

Regime	Who in the cell	Their clock	Their recipient
CRA Art 14	PSIRT lead, Assigned Representative	24 h, 72 h, 14 days or 1 month from awareness	Coordinator CSIRT and ENISA via the SRP
NIS2 Art 23	Infrastructure CSIRT, NIS2 compliance owner	24 h, 72 h, 1 month	National CSIRT or competent authority
GDPR Art 33	Data protection officer	72 h from awareness of the breach	Data protection authority
DORA Art 19	ICT risk function of the financial entity	Initial, intermediate, final per the RTS	Financial competent authority

The cell shares one fact base and one UTC timeline, and each owner files separately. The Digital Omnibus proposal (COM(2025) 837) would let a CRA severe-incident report satisfy NIS2 Art 23(4) and would move GDPR to 96 hours. Both remain proposals, with trilogues not started as of 30 Oct 2026, so the cell plans for cumulative filing.

Customer and user communication governance

Art 14(8) requires the manufacturer to inform impacted users, and where appropriate all users, in a timely manner (no fixed deadline), "where appropriate, in a structured, machine-readable format". Guidance paras 219-221 make the duty risk-based: detailed disclosure may be limited to affected customers until a fix exists, with broader disclosure once mitigated. If the manufacturer is not timely, the CSIRTs may inform users themselves.

Decision	Owner	Rule
Who is told first	PSIRT lead with product management	Affected customers with mitigations before public disclosure; wider notice once mitigated

Decision	Owner	Rule
Wording	Legal with communications	Pre-approved templates, human-readable and machine-readable; CSAF is the obvious format but no primary source names one
Channels	Support and sales leadership	Named customer contacts, in-product notices, advisory page, security.txt pointers
Timing relative to filings	PSIRT lead	User notice is not gated on the SRP filing, and the SRP filing is not gated on the user notice
Record	PSIRT	Who was told, when, through which channel, with the message text

Support and sales staff need a script: what has happened, what to do, where the advisory is, and what not to speculate about. Section 9 covers their training.

Drills twice a year

Run two tabletop exercises a year: one actively exploited vulnerability in a third-party component, one severe incident affecting an update channel or signing key. Never submit synthetic reports to the live SRP; there is no sandbox (ENISA SRP FAQ). Rehearse on paper against the glossary field names.

Each drill tests awareness declared by a deputy at a weekend, platform access by a Secondary Assigned Representative and an unresponsive supplier. It also tests the multi-regime cell, user-notification wording and the UTC timeline. Record the results against the 24-hour and 72-hour targets as a KPI (Section 11) and feed lessons into the runbook within a month.

Records

- UTC timestamps for first signal, organisational awareness, internal escalation and each SRP submission. The glossary's mandatory "date and time became aware" field must match the case file.
- A decision log entry for every awareness declaration and every "not reportable" decision, naming the criterion and the decider.
- The internal case file as the authoritative record; the SRP is a submission surface whose drafts live in one person's account.

- Submission receipts and notification identifiers, retained with the technical documentation for 10 years or the support period (Art 13(13)).
- Patch-availability dates tracked internally, because the actively-exploited-vulnerability final report has no SRP counter.
- User-notification records under Art 14(8).
- Drill records and lessons learned.

Reporting governance checklist

- [ ] PSIRT and infrastructure CSIRT defined as separate roles with separate mailboxes and keys
- [ ] Awareness authority, deputy chain and written criteria in the runbook; no approval step before the early warning
- [ ] Legal review placed on the 72-hour and final reports only
- [ ] At least two Assigned Representatives registered with EU Login, MFA and backup devices; roster and offboarding rule in force
- [ ] Coordinator CSIRT decision record signed before any incident, per manufacturer entity
- [ ] Multi-regime cell membership and clocks documented
- [ ] User-notification templates pre-approved, human-readable and machine-readable
- [ ] Two drills scheduled for the year with results feeding the KPIs

8. Evidence and records management

The CRA is enforced on documents, so the organisation needs one system of record for product compliance evidence, not mailboxes and spreadsheets. Early adopters with mature security programmes "could not show the decision trail"; evidence sat across ticketing, file shares, test platforms and email (OmniTrust, consultancy). Formal non-compliance, such as unavailable or incomplete technical documentation, is enforceable on its own under Art 58.

This section defines what the system holds per product version, for how long, and how it is versioned and controlled. It then covers answering an authority, custody with representatives and importers, the product-liability dimension from 9 Dec 2026 and the audit trail.

The system of record

The system of record is wherever the organisation chooses to keep controlled, versioned, access-managed records with an audit trail. A GRC platform, a document-management system or a dedicated product-compliance tool all qualify. A shared drive with naming conventions does not, and neither does the ENISA SRP, whose drafts live in one individual's account.

Property	Requirement	Why
Single index	Every product version in the scope register (Section 4) resolves to its evidence set	Annex VII point 1(b): software versions affecting compliance must be identifiable
Immutable versions	Records are superseded, not edited; the state at placing on the market is recoverable	Art 31(2): documentation drawn up before placing and kept current; authorities ask about the version placed
Machine-readable where possible	SBOMs, VEX, attestations, test outputs stored as data, not screenshots	ENISA Playbook v1.0 Section 5.1: machine-processable attestations keep documentation current
Pipeline-fed	Release gates write their records automatically; humans add decisions	Reduces hand assembly for each request
Access-controlled	Role-based access with a log of reads and exports	Art 13(22) responses and Art 64(4) exposure need to show who saw and sent what
Exportable	A complete technical file per version exports as a package an authority can read	Art 13(22): paper or electronic form, in a language the authority understands
Retained	Retention rules enforced by the system, not by memory	Arts 13(13), 13(18), 18(3), 19, 23

What it holds per product version

Record	CRA basis	Produced by	Notes
Technical documentation per Annex VII	Art 31; Annex VII points 1-8	Compliance lead assembles from the records below	BSI TR-03183-1 v1.0.0 Section 4.8 is a usable skeleton until EN 40000-1-x is cited
Cybersecurity risk assessment with the Annex I applicability matrix	Art 13(2)-(4), (7); Annex VII point 3	Product security officer (Section 5)	Signed, with decision trail and update log
SBOM per release	Annex I Part II(1); Annex VII points 2(b), 8	Build engineering	Signed, with known unknowns; supplied to an MSA on reasoned request; not public by default (Recital 77)
VEX and CSAF statements and advisories	Annex I Part II(2), (4); guidance para 218	PSIRT	"Not_affected" statements are evidence that no Art 14 report was due
Test evidence	Annex I Part II(3); Annex VII point 6	Security testing	SAST, DAST, fuzzing, penetration tests, re-tests on new threat input
Release security gate record	Annex I Part I(2)(a); guidance paras 230-237, 104-124	Release manager	Exploitability decision, SBOM hash, secure-default check, security-delta assessment
EU declaration of conformity	Art 28; Annexes V-VI	Legal with compliance lead	DoC id, signatory, authority instrument reference (Section 2)
Annex II user information	Art 13(18); Annex II	Technical writing	Each published version, with the end-of-support date shown

Record	CRA basis	Produced by	Notes
Classification and scope decision records	Arts 2, 7; Section 4	Compliance lead	Guidance paragraphs relied on and their version
Conformity assessment records	Art 32; Annex VIII	Compliance or quality lead	Module A record; Module B certificate and change notifications; Module H approvals, changes and audit reports
Supplier and component evidence	Art 13(5)-(7); Art 23	Procurement, engineering, OSPO	Questionnaires, SBOMs, attestations, intake-gate records, upstream reports
Support-period determination	Art 13(8); Annex VII point 4	Product management	The information taken into account, per version
Reporting records	Art 14; Art 16	PSIRT	Case files, UTC timelines, decision logs, SRP receipts, user notifications, drill records (Section 7)
Standards and guidance applied	Annex VII point 5	Compliance lead	Which standards, specifications and guidance versions, fully or partly applied
Traceability records	Art 23	Supply chain operations	Who supplied you and whom you supplied, 10 years each way

Retention

Record	Period	Source
Technical documentation and EU declaration of conformity	At least 10 years after placing on the market, or the support period, whichever is longer	Art 13(13); Annex VIII Module A pt 4.2, B pt 10, C pt 3.2, H pts 5.2 and 6

Record	Period	Source
User information and instructions	At least 10 years or the support period, whichever is longer	Art 13(18)
Copies held by an authorised representative	10 years or the support period, whichever is longer	Art 18(3)
Copy of the declaration held by an importer	10 years or the support period, whichever is longer	Art 19
Traceability of operators up and down the chain	10 years after being supplied and 10 years after supplying	Art 23
Module B certificate, annexes and additions	With the technical documentation, 10 years or the support period	Annex VIII Module B pt 10
Module H quality-system documentation, approved changes, body decisions and audit reports	At least 10 years or the support period	Annex VIII Module H pt 6
Security updates themselves	Available for at least 10 years or the remainder of the support period	Art 13(9)
Reporting case files and receipts	Align to the technical documentation period for the product concerned	Internal rule; Art 16(3) makes reports visible to MSAs

Because the support period for a long-lived product can exceed 10 years, the retention clock is per version and ends at the later date. The system must compute it from the scope register, not from a fixed policy figure.

Versioning tied to releases

1. Every release that passes the gate creates or updates a version record; nothing is filed against "the product" without a version.
2. The record carries the state of each artefact at placing on the market, plus later updates with their dates. Both Art 31(2) currency and the original state are then recoverable.
3. A substantial modification opens a new version lineage with its own risk-assessment delta and support period (guidance paras 104-124). It may need its own DoC (FAQ Section 6.8).

4. A product family may share one risk assessment, technical file and DoC (guidance paras 174-177). Each variant still resolves to that shared set.
5. Guidance para 113 requires documentation kept "accurate, complete and continuously up to date" whether or not an update is substantial. The pipeline feed meets that without hand editing.

Answering an authority

Art 13(22) requires the manufacturer to answer a reasoned request from a market surveillance authority with all information needed to demonstrate conformity. It may be on paper or electronic, but must be in a language the authority easily understands. The text sets no deadline, so set an internal one and name the owner.

Step	Owner	Target
Log the request, its legal basis and the authority's language	Compliance lead	Same day
Confirm the product versions concerned from the register	Compliance lead	Day 1
Export the technical file package for those versions	System of record	Day 2
Legal review of the package and the covering response	Legal	Days 3-7
Translation or summary where the file is not in a language the authority understands	Compliance lead	Within the target
Deliver, log recipient, date and contents	Compliance lead	10 working days

Ten working days is an internal target, not a legal deadline. Documentation may be kept in a working language of your choice, but a notified body can require its own Member State's language or one it accepts (Art 31(4)), and the authority is entitled to a version it easily understands (Art 13(22); FAQ Section 6.6). Plan translation capacity for the Member States in the register.

The knowledge base, Enforcement, market surveillance and penalties, covers the powers behind the request.

Expect requests informed by your own filings. Art 16(3) feeds every Art 14 report to the market surveillance authorities, and Art 60 lets ENISA propose sweeps from that data. Art 13(25) lets MSAs request SBOMs for ADCO dependency assessments outside any investigation.

Custody with the authorised representative and importers

An authorised representative must keep the DoC and technical documentation for 10 years or the support period (Art 18(3)). It must supply them on reasoned request. An importer must keep a copy of the DoC for the same period and verify that the technical documentation exists (Art 19).

Both therefore need a controlled copy or controlled access, not an email attachment.

- Give the representative read access to the system of record for the products in its mandate. Alternatively, deliver a versioned package at each placing and update.
- Record in the mandate which Annex VIII tasks the representative performs, since Modules A, B, C and H each allow delegation of specified points.
- Supply importers with the DoC per version and a confirmation that the technical documentation exists, logged in the system.
- On a change of representative or importer, transfer custody formally and record it; the 10-year duty follows the product, not the contract.
- Review custody arrangements at the quarterly review and on any market change in the register.

The product-liability dimension from 9 Dec 2026

Directive (EU) 2024/2853 applies to products placed on the market from 9 Dec 2026. Software is a product, a cybersecurity vulnerability can be a defect (recital 32), and Art 9 gives claimants a right to disclosure of evidence. The CRA technical file, SBOM, risk assessment and update logs therefore become disclosable evidence in civil claims, and the main defence file.

Three consequences follow. Art 10(2)(b) presumes defectiveness where the claimant shows non-compliance with mandatory safety requirements, which Annex I becomes from 11 Dec 2027. Art 11(2)(c) removes the later-defect defence for a lack of software updates within the manufacturer's control, so update logs matter.

Art 7(2)(f) counts "safety-relevant cybersecurity requirements" in assessing defectiveness, so courts as well as authorities will read the applicability matrix.

Write records as if they will be disclosed. Decision trails, justifications and risk acceptances should stand on their own without oral explanation. See the knowledge base, Interplay with other law, the Digital Omnibus and the UK position.

Audit trail for answers to authorities

Art 64(4) fines incorrect, incomplete or misleading information supplied to notified bodies or authorities in reply to a request. The ceiling is EUR 5m or 1% of worldwide turnover. The exposure sits on the content of the answer, so the trail must show who said what to whom.

- Every outbound answer to an authority or notified body is logged with author, approver, recipient, date, the question and the documents sent.
- Answers are drawn from the system of record, not reconstructed; where a statement cannot be evidenced, it says so.
- Corrections are filed as new entries referencing the original, never by editing the original.
- Oral exchanges, such as calls with a CSIRT or notified-body auditor, are minuted and filed the same day.
- Legal reviews any statement about conformity, classification or awareness before it leaves (Section 2).
- The trail is sampled by the third line of assurance (Section 5).

Evidence checklist

- [ ] System of record chosen and every scope-register row resolves to a version-level evidence set
- [ ] Retention computed per version from the support period, with the later of 10 years or support period enforced
- [ ] Release gate writes its record automatically; manual records are the decisions only
- [ ] Reasoned-request procedure tested end to end against the 10 working-day target, with translation capacity identified
- [ ] Authorised representative and importers hold controlled copies or access, recorded in the mandate
- [ ] Records reviewed for disclosure readiness under Directive (EU) 2024/2853 Art 9
- [ ] Outbound-answer log in use for every authority and notified-body contact

9. Training and enablement

Training turns the policies in Section 3 into behaviour, and the survey evidence says most organisations have not started. Bitkom found 29% of German companies know what the CRA means for them (Apr-Jun 2026, 1,003 companies, survey). The Linux Foundation

found 56% of CRA-aware respondents unaware of penalties and only 34% identifying 2027 as the compliance year (LF 2026, 404 CRA-aware respondents of 843 surveyed, survey).

The ENISA SME survey found templates to be the single most requested support, at 73% of respondents (Jun 2026, 194 responses, not representative). This section therefore pairs role-based training with the enablement assets each role needs to act. Module H assessors also look for competence and training records (Annex VIII pt 3.2(g)).

Role by content

Role	Must know	Must be able to do	Depth and cadence
Executives and board	The obligations in Arts 13-14; fine tiers in Art 64 (EUR 15m or 2.5%; EUR 10m or 2%; EUR 5m or 1%); the decision rights in Section 2; that cost cannot justify unaddressed product risk (guidance paras 156-163); the 11 Sep 2026 and 11 Dec 2027 dates	Sign or delegate the DoC on evidence; hear a residual-risk appeal; read the Section 11 KPIs	90 minutes at programme start; annual refresh; briefing on each guidance version change
Engineering leads and developers	Annex I Part I patterns for (2)(a)-(m); the applicability matrix; SBOM generation and quality; secure update design; the release gate; the substantial-modification test; Art 13(5)-(6) component duties	Threat-model a product; justify a non-applicable item; produce a release-gate record; file an upstream report	Half-day at onboarding; per-release refresher through the gate checklist; annual update

Role	Must know	Must be able to do	Depth and cadence
PSIRT	Awareness criteria (guidance para 213; FAQ 5.2, 5.4); the SRP, its roles and limits; the 24-hour, 72-hour and final-report content; CVD policy and disclosure timelines; VEX and CSAF; the multi-regime cell	Declare awareness; file an early warning on a weekend; write a "not reportable" decision; publish an advisory	Full day at appointment; two drills a year; monthly case review
Product management	Support-period determination and the five-year floor (Art 13(8)); Annex II content; end-of-support display and notification (Art 13(19)); the scope register fields; the version placing rule for software	Set and document a support period; draft Annex II information; raise a register change	Half-day; refresh at each guidance change on Section 5 of the guidance
Procurement and legal	The Section 6 contract clauses; roles under Arts 18-22 and when a reseller becomes manufacturer; FOSS determinations and the steward test (guidance paras 40-88); Art 13(22) requests and Art 64(4) exposure; PLD disclosure from 9 Dec 2026	Negotiate the clauses; write a steward determination; review a 72-hour report; answer an authority	Half-day; refresh at each guidance or case-law change

Role	Must know	Must be able to do	Depth and cadence
Support and sales	What the CRA promises customers: support period, security updates, where the DoC, Annex II information and CVD policy are published; what to say during an incident; where SBOM access sits if the organisation offers it (Annex II point 9)	Answer a customer's CRA questionnaire from the published material; route a vulnerability report to PSIRT within the hour; use the incident script	Two hours; refresh with each incident template change
Internal audit and compliance sampling	The three lines of assurance (Section 5); what a complete Annex VII file looks like; retention rules; the reasoned-request procedure	Sample a technical file; test the system of record; report to the programme board	Half-day; annual

Support and sales deserve more attention than they usually get. Customers under NIS2 and DORA will ask for the DoC, SBOM access, support period and CVD policy as supply-chain evidence. See the knowledge base, Interplay with other law, the Digital Omnibus and the UK position.

A sales team that improvises answers creates exposure under Art 64(4) if those answers reach an authority.

Enablement assets to produce

Asset	For whom	Built from	Owner
PSIRT runbook with awareness criteria, deputy chain, SRP steps and templates for the three report stages	PSIRT, on-call	ENISA SRP glossary and AR manual v1.2; BSI TR-03183-3; Section 7	PSIRT lead

Asset	For whom	Built from	Owner
Risk assessment and applicability matrix template with worked justifications	Engineering, product security	BSI TR-03183-1 Sections 4.8, 5-6 and Annex C network-camera example; ENISA Playbook v1.0 Section 2.3	Product security officer
Release-gate checklist and record template	Release managers	Knowledge base, Engineering compliance programme; OpenChain CRA checklist (community draft)	Product security officer
SBOM pipeline template and quality checks	Build engineering	ENISA SBOM advisory v1.10 Section 4.1; BSI TR-03183-2 fields	SBOM owner
CVD policy, security.txt and advisory templates	PSIRT, web team	ENISA SME Vulnerability Kit (Oct 2026, consultation draft); TR-03183-3 Section 4.4	PSIRT lead
Support-period determination template and end-of-support notice	Product management	Guidance C(2026) 5252 Section 5; Annex II point 7	Product management
Annex II information template	Technical writing	Annex II points 1-9; knowledge base, Annex I Part II: vulnerability handling and lifecycle duties	Technical writing lead
Scope and classification decision-record template	Compliance, product	Section 4; guidance Sections 2, 6 and 8; Implementing Regulation (EU) 2025/2392	Compliance lead
Supplier clause pack and questionnaire	Procurement	Section 6; VDMA self-disclosure guideline (trade association)	Procurement

Asset	For whom	Built from	Owner
Steward determination memo and Art 24(1) policy template	Legal, OSPO	ORC WG white paper V1.0; LF Stewards Playbook	Legal
Customer-facing CRA fact sheet and incident script	Support, sales	Published DoC, Annex II, CVD policy, support-period table; Section 7 communication rules	Product management with legal
Worked examples: one default product, one Class I product, one software-only product, one legacy product	All	The representative products from the first wave (Section 11)	Compliance lead
Executive briefing deck and quarterly dashboard	Executives, board	Sections 2 and 11	Compliance lead

Produce the worked examples from the first wave's real products, not hypotheticals. Consultancy practice recommends piloting the record set on one representative product before scaling (SCHUTZWERK, vendor), and the same pilot yields the training material.

Reference material to build from

Source	Status on 30 Oct 2026	Best used for
ENISA Secure by Design and Default Playbook v1.0 (Jul 2026)	Published; 22 principle playbooks with "minimum evidence" per principle; Annex B reproduces Annex I; Annex C indicative mapping	Developer training on Annex I patterns; threat-modelling method for small teams
BSI TR-03183-1 v1.0.0 (31 Jul 2026, living document)	Non-binding; OSCAL controls on request from BSI	Risk-assessment method; the Annex C worked example as a classroom case
BSI TR-03183-2 v2.1.0 (20 Aug 2025)	Non-binding	SBOM field and depth training for build engineers
BSI TR-03183-3 v1.0.0 (20 Aug 2025)	Non-binding	PSIRT set-up: security.txt, mailboxes, CVD policy content, response targets

Source	Status on 30 Oct 2026	Best used for
BSI TR-03183-H v1.1.0 (30 May 2026)	Non-binding	Module H and ISMS extension for quality and compliance staff
ENISA SRP FAQ (31 items), glossary, AR user manual v1.2 (21 Oct 2026), factsheet in 10 languages	Live	PSIRT and Assigned Representative training; the factsheet for non-specialists
ENISA SME Vulnerability Kit (Oct 2026)	Consultation draft	CVD policy and advisory templates; the "common mistakes" table as a teaching aid
ENISA SBOM advisory v1.10 (Oct 2026) and package-manager advisory (10 Mar 2026)	Published, non-mandatory	Pipeline and consumption-policy training
ENISA update mechanisms advisory v0.1 (May 2026)	Draft	Secure update design; label as draft
ORC Learning Hub	Live; two introductory courses	Open-source-focused CRA training for OSPO and maintainers
OpenSSF guides: Stewards Playbook, One Pager, maintainer readiness guide, manufacturer checklist, OSPS Baseline	Living documents	Steward and OSPO enablement; component selection criteria
Commission FAQ v1.4 and guidance C(2026) 5252	Non-binding; guidance formally a draft pending language versions	Legal and product-management training on scope, support period, substantial modification and awareness
Knowledge base sections and the Requirement checklists tab	Internal	The per-item questions every role trains against

Label every training asset with the source version it rests on. When the FAQ or guidance changes, or when EN 40000-1-3 is cited, the quarterly review (Section 2) triggers an update to the affected assets.

Training checklist

- [ ] Role-by-content matrix adopted and mapped to the organisation's actual roles
- [ ] Executive briefing delivered and minuted, including the residual-risk rule
- [ ] Developer and PSIRT training delivered before the first release-gate run and the first drill
- [ ] Support and sales script and fact sheet issued before any public DoC
- [ ] Thirteen enablement assets produced, each labelled with its source version
- [ ] Worked examples built from the first wave's real products
- [ ] Competence and training records filed in the system of record (Section 8)

10. Market access: notified bodies, EU representation, CE marking

Market access for important products depends on capacity the organisation does not control, so it has to be secured early and hedged. No CRA notified body was verifiably listed in NANDO at checks to 8 Sep 2026; the Commission's page still says "once available". Art 35(2) only asks Member States to "strive" for sufficient bodies by 11 Dec 2026.

This section covers selecting and contracting notified bodies before any is designated, and keeping Module A paperwork complete regardless. It then covers EU representation, CE marking and the DoC, marketplace arrangements and the UK lines. The route rules per class are in the knowledge base, Conformity assessment and documentation.

Selecting notified bodies while none is designated

Designation is a leading-indicator game. Accreditation in practice runs against EN ISO/IEC 17065 for Modules B+C and EN ISO/IEC 17021-1 for Module H (accreditation practice; not stated in the CRA text). The notifying authority then notifies through NANDO, with a two-week objection window for accredited bodies (Art 43).

A body's accreditation certificate is therefore the signal that designation is weeks, not months, away.

Candidate signal	What is public	Label
Brightsight (SGS, NL)	ISO/IEC 17065 accreditation from RvA for Module B, notification via the Dutch RDI as the next step; Module H status described inconsistently	Vendor statement

Candidate signal	What is public	Label
Applus+ Laboratories	"Progressing through" accreditation and notification; targets Module B+C; offers a "Module B + C simulation" pre-assessment	Vendor statement
TÜViT (TÜV NORD)	Says it "will apply to the BSI" for Module H designation; sells gap assessments and a two-day roadmap workshop	Vendor statement
DEKRA	Says it "will be a Notified Body for CRA"; CRA Pilot Program; notification "starts in June 2026"	Vendor statement
Others presenting at the 2026 EU Cyber Act conference: Bureau Veritas Cybersecurity, jtsec, DNV Cyber, CCLab, TÜV SÜD, secuvera, atsec, Intertek	Conference presence; no designation claims	Ecosystem signal, not status

Shortlist three, preferring bodies already accredited for EUCC or the RED delegated act. RED-notified bodies must be newly assessed for the CRA (Recital 100) but have the staff and procedures. Check the Single Market Compliance Space listing for Regulation (EU) 2024/2847 at each programme board.

Pre-assessment contracts and what to ask

Labs sell gap assessments, readiness checks and pre-assessments today under their own names, not as notified bodies. Use them to make the technical file assessment-ready and to secure a place in the queue. Record that none of this is a conformity assessment under Art 32.

1. Contract a pre-assessment with two or three candidates on a representative product per family. Write in conversion to a formal Module B or H engagement as an option.
2. Ask each candidate the questions below and file the answers in the system of record (Section 8) as the basis for the selection decision.
3. Prepare the Annex VIII application contents now. Module B needs the technical documentation with "an adequate risk analysis" and a declaration that no other body has the application (pt 3). Module H needs the quality-system documentation and one technical file per product category (pt 3.1).

4. Agree in writing how the candidate handles the transition if it is not designated in time, including return of documentation and release from exclusivity.
5. Target contracting a formal slot by Q1 2027 working back from 11 Dec 2027, as commentary suggests (CRA Decoded, commentary).

Question	Why it matters
Scope of accreditation sought: EN ISO/IEC 17065, 17021-1 or both; which notifying authority; expected notification date	Determines whether Module B+C or H is available from this body and when
Which Annex III and IV categories the body intends to cover	A body may be notified for some categories only (Art 43)
Lead time from contract to certificate	No lab publishes one; vendor estimates run 3-6 months for Module B+C once engaged, labelled unverified
Surveillance terms: frequency of Module B pt 8 vulnerability-handling audits or Module H pt 4 audits; site access; fees	Module H surveillance is "typically every one to two years" (vendor estimate)
Fees: per type examination, per quality-system approval, per surveillance cycle, per scope extension	Vendor estimates run EUR 20,000-60,000 per Module B examination and EUR 80,000-150,000 for a first Module H engagement; unverified
Handling of substantial modifications: additions to a Module B certificate (pt 7) or Module H scope extension (FAQ Section 6.3)	Decides the running cost of a fast-moving portfolio
Treatment of draft standards as evidence under Annex VII point 5	Nothing gives presumption until cited, but the body's view shapes the file
Independence and SME terms under Arts 39 and 47	Fees must consider SMEs proportionately (Art 32(6)); assessments must avoid "unnecessary burdens"
Subcontracted testing and where tests take place (Module B pt 4.5)	Logistics and confidentiality
Confidentiality and the body's reporting duties to its notifying authority (Module B pt 9)	What the body will share with authorities and other bodies

Keeping Module A paperwork complete regardless

Module A internal control is the default route and the fallback for every other. Its paperwork is the Annex VII file, the Annex I process measures, the CE marking and a written DoC (Module A pts 2-4). Every Class I and II product should hold a complete Module A record even while waiting for a body.

Three reasons. A Class I product becomes Module A eligible once a cited harmonised standard covering its core-functionality risks is fully applied (guidance paras 148-151). An Annex III product that is FOSS may use Module A if its Annex VII documentation is public (Art 32(5)).

And the Module B application is the Module A file plus supporting evidence (Module B pts 3.3-3.4), so nothing is wasted.

EU representation for non-EU manufacturers

A non-EU manufacturer, including one in Great Britain, carries Arts 13-14 itself. The CRA does not force it to appoint anyone in the EU, because Art 18 is permissive. Art 66 adds the CRA to Annex I of Regulation (EU) 2019/1020, not to the Art 4(5) list that mandates an EU responsible operator.

Confirm that reading with counsel; the knowledge base, Economic operators and roles, explains both readings.

Instrument	What it does	Mandatory?
Authorised representative (Art 18)	Holds the DoC and technical documentation for 10 years or the support period; answers reasoned requests; cooperates with authorities; cannot take on Art 13(1)-(11), 13(12) first subparagraph or 13(14)	Optional ("may")
Importer (Art 19)	Verifies conformity assessment, documentation, CE marking, DoC and Annex II information before placing; adds its own name and contact; informs the manufacturer of vulnerabilities; keeps the DoC	Exists by definition where an EU business places the product; absent in pure direct-to-consumer sales

Instrument	What it does	Mandatory?
Reg 2019/1020 Art 4 responsible operator	Required for the legislation listed in Art 4(5), such as the Radio Equipment Directive	Not for the CRA as such; yes where the product is also radio equipment
GPSR Art 16 responsible person, via CRA Art 11	EU-established person for consumer products not under other harmonisation law, for safety risks the CRA does not cover	Yes for in-scope consumer products without other harmonisation law
Directive (EU) 2024/2853 Art 8	Where no EU importer or authorised representative exists, the EU fulfilment service provider is liable (Art 8(1)(c)(iii)); an online platform only if it fails to identify an EU operator within one month of a request and DSA Art 6(3) applies (Art 8(3)-(4))	Liability from 9 Dec 2026, not a market-access condition

The practical advice is to appoint an authorised representative anyway. It fixes the Art 14(7) coordinator CSIRT for a manufacturer with no EU establishment and gives authorities one EU address. It also keeps custody of the file (Section 8) and keeps liability off fulfilment partners.

Write the mandate to cover the Annex VIII points the module allows to be delegated.

CE marking and labelling responsibilities

Duty	Rule	Owner
Affix the CE marking before placing on the market	Visibly, legibly and indelibly on the product; else on the packaging and the DoC (Art 30(1), (3))	Production or release management
Software	On the EU declaration of conformity or on the website accompanying the software, in a section "easily and directly accessible to consumers" (Art 30(1))	Release management with the web team

Duty	Rule	Owner
Size	Generally at least 5 mm; smaller only where the product's nature requires, not for aesthetics (Art 30(2); FAQ Section 6.7)	Production
Notified-body number	Follows the CE marking only under Module H, affixed by the body or under its instructions (Art 30(4); Annex VIII Module H pt 5.1)	Compliance lead with the body
No marking without a positive assessment	The CE marking cannot be affixed until the conformity assessment is complete (FAQ Section 6.7)	Compliance lead
Other CE legislation	One marking indicates compliance with all applicable CE legislation (Art 30(5))	Compliance lead
Future labels	Art 30(6) implementing acts on pictograms and support-period marks; none adopted	Watch at the quarterly review

For software-only products a single public compliance page is the efficient pattern. It carries the CE marking, the DoC, the Annex II information, the support-period table and the CVD policy (knowledge base, Engineering compliance programme). No authority example exists yet, and app-store presentation of the CE mark is unaddressed in any source read.

Declaration signing authority and format

The DoC follows Annex V, or Annex VI simplified with "the exact internet address" of the full text (Art 13(20); Art 28(2)). It must accompany the product, be in the languages required by the Member States of sale, and be updated as appropriate. A single DoC may cover a product family that clearly identifies the variants (guidance para 175) and several Union acts (Art 28(3)).

Signing is a controlled authority: Section 2 sets out the instrument, the pre-signature checklist and the counter-signature. Annex V item 7 records any notified body, procedure and certificate; item 8 carries the signatory's name, function, signature, place and date. A

new version "might need a new declaration", especially after a substantial modification (FAQ Section 6.8).

Marketplace and direct-to-consumer arrangements

- An online offer targeted at EU end users is "made available on the market" (Reg 2019/1020 Art 6). A web shop selling into the EU places the product there.
- A marketplace or fulfilment provider is not a CRA economic operator unless it manufactures, imports or distributes (Recital 78). One selling its own brand is a manufacturer.
- In direct-to-consumer sales there is no importer, because a consumer does not act in a commercial activity; the manufacturer alone carries Arts 13-14.
- The GPSR Art 16 responsible-person rule and, where applicable, Reg 2019/1020 Art 4 still require an EU person for consumer products.
- From 9 Dec 2026 the fulfilment service provider is liable under Directive (EU) 2024/2853 Art 8(1)(c)(iii) where no importer or representative exists, and a platform can become liable if it cannot name an EU operator within one month of a request (Art 8(3)-(4)). Platforms will therefore ask for one.
- Expect test purchases under "cover identity" in coordinated sweeps from 11 Dec 2027 (Art 60).
- Each marketplace listing is a market and channel entry in the scope register (Section 4) with its own role decision.

UK-specific lines

Point	Position on 30 Oct 2026
GB manufacturers	Third-country manufacturers for the CRA; Arts 13-14 apply to any product made available in the EU
UK Approved Bodies	Can only certify for UKCA marking; they cannot act as EU notified bodies, so CRA third-party assessment needs an EU notified body (gov.uk UKCA guidance, 21 Aug 2026)
Mutual recognition	Art 34 allows agreements; none covering CRA conformity assessment was found

Point	Position on 30 Oct 2026
Northern Ireland	The CRA is not in Annex 2 of the Windsor Framework; only Arts 66 and 68 apply via Art 13(3); Council Decision (EU) 2025/799 proposes adding it; the Art 13(4) exchange of views concluded 7 May 2026 with no Joint Committee decision found; UK agreement requires Schedule 6B safeguards
If the CRA is added to Annex 2	In-scope NI supplies would move from PSTI to the CRA (SI 2023/1007 Sch 3 para 1); NI manufacturers remain third-country manufacturers until then
UK regime	PSTI (in force 29 Apr 2024; three requirements; OPSS; GBP 10m or 4%); the Cyber Security and Resilience Bill has no product-security duties; the 28 Oct 2026 Budget committed to a 2027 consultation on "insecure technology at source"
Reporting route for GB manufacturers	Art 14(7): the authorised representative's Member State, else importer, distributor, then most users; appoint a representative to make this certain

UK groups should budget for an EU notified body, an authorised representative and EU-language DoCs as separate lines (Section 11). The knowledge base, Interplay with other law, the Digital Omnibus and the UK position, carries the detail and the open Northern Ireland question.

Market access checklist

- [ ] Three candidate bodies shortlisted with accreditation status checked at each programme board
- [ ] Pre-assessment contracts in place on a representative product per family, with conversion options and exit terms
- [ ] Module A record complete for every product, including Class I and II
- [ ] Representation decision per market: authorised representative appointed, importer identified, GPSR and Reg 2019/1020 Art 4 checked
- [ ] CE marking placement decided per product type, including the software compliance page
- [ ] DoC format, languages and family coverage decided; signing instrument in force (Section 2)
- [ ] Marketplace listings entered in the scope register with role decisions

- [ ] UK lines reflected in budget and representation plans; Northern Ireland status reviewed quarterly

11. Programme plan, budget and metrics

The portfolio programme runs the phases from the knowledge base, Engineering compliance programme, as waves rather than as one project. Each wave takes a set of products through inventory, risk assessment, remediation, documentation and conformity assessment. Each later wave reuses what the first produced; the phase dates, outputs and gates are in that section's roadmap.

This section covers wave planning, budget lines, the KPIs the programme board tracks and what the board itself sees. The benchmark figures are thin; all are survey or vendor material and are labelled as such.

Running the phases at portfolio level

Principle	How it works	Why
Wave by class and revenue	Wave 1: Class I and II products with the highest revenue or exposure, plus one default product as a control. Wave 2: remaining important products. Wave 3: default products by revenue. Wave 4: legacy products due for substantial modification	Important products face the notified-body constraint; revenue decides what cannot be left off the market on 11 Dec 2027
Representative product first	One product per family goes through every phase before the rest of the family starts; its records become the templates and worked examples (Section 9)	Consultancy practice: pilot the record set on one product, then scale (SCHUTZWERK, vendor); lab practice: gap-assess a representative product (Nemko, vendor)
Parallel documentation	Technical-file assembly starts when the risk assessment is signed, not when remediation ends; families share one file where guidance paras 174-177 allow	Phase 4 runs in parallel at 2-4 months per family; waiting for remediation to finish pushes documentation into the notified-body window

Principle	How it works	Why
Reporting first, everywhere	Phase 0 covers the whole portfolio, including legacy products, before any wave starts	Art 14 applies now (Art 69(3)); it does not wait for waves
Shared services, product decisions	SBOM pipeline, update infrastructure, PSIRT, system of record and policies are built once; scope, class, risk and support period are decided per product	Engineering uplift is the largest cost (phase 3); sharing it is where the saving is
Notified-body slot drives the wave calendar	Wave 1 contracting by Q1 2027 (commentary), with assessment from Q2 2027; Wave 2 slots follow	Phase 5 is the constraint; vendor estimates give 2-4 months to contract and 3-6 months per Module B+C engagement, unverified
Guidance changes are re-planned, not absorbed	A cited harmonised standard, a new FAQ version or a notified-body designation triggers a wave review at the next programme board	Class I products may switch to Module A on citation; records relying on old guidance are superseded (Section 4)

A mid-size manufacturer should expect 12 to 18 months from a standing start to assessment-ready for an important product. That is roughly the time left to 11 Dec 2027 (an inference in the research notes, not an authority figure). The waves therefore overlap: Wave 2 inventory and risk assessment start while Wave 1 is in remediation.

Budget lines

Line	What it covers	Benchmark, labelled
People	Compliance lead, product security officer, PSIRT lead and on-call, SBOM owner per release train, line 2 reviewers, programme management; engineering time for remediation	ONEKEY (Sep 2026, 200 German industrial firms, vendor survey): 28% have CRA teams of up to 10 people, 22% larger, 16% up to 3; over 60% expect longer development, 28% "significantly longer". No authoritative FTE benchmark exists

Line	What it covers	Benchmark, labelled
Tooling	SBOM generation and quality (Syft, Trivy, cdxgen, sbomqs), signing and attestation (cosign), dependency monitoring (Dependency-Track), VEX and CSAF, threat-modelling tools, the system of record, SRP access devices	ENISA SBOM State of Play 2026 (survey) (334 responses): 74% have partly or fully automated SBOM generation; completeness is the top challenge at 62%. Open-source tooling dominates ENISA's landscape table
Notified-body fees	Pre-assessments, Module B type examinations, Module H quality-system approval and surveillance, scope extensions	Vendor estimates, unverified: EUR 20,000-60,000 per Module B examination; EUR 80,000-150,000 for a first Module H engagement with surveillance every 1-2 years (CRA Decoded, commentary); another vendor gives EUR 15,000-80,000 for Module B (sota.io, unsourced)
External testing	Penetration tests, fuzzing, binary SCA, lab gap assessments	cyberresilienceact.eu calculator (independent model, illustrative): security testing EUR 6,400 within a EUR 78,300 one-off for three default products at medium readiness and EUR 45 per hour
Training	Role-based training (Section 9), drills, ORC Learning Hub and vendor courses	ENISA SME survey (Jun 2026, 194 responses, not representative): 73% want technical documentation templates; 13% rate their documentation understanding good
Legal	Steward determinations, supplier clause negotiation, authorised-representative mandate, DoC signing instrument, reasoned-request responses, PLD readiness	LF 2026 (survey, 28 stewards): 39% of stewards cite legal guidance as a support need (47% in 2025, n=34)

Line	What it covers	Benchmark, labelled
Representation and market access	Authorised representative fees, EU-language DoCs and Annex II translations, marketplace compliance	No benchmark found; UK groups carry this as a separate line (Section 10)
Running cost after go-live	Vulnerability handling, security updates, surveillance audits, standards re-mapping, SRP operation	Calculator (illustrative): EUR 13,500 a year for three default products; vulnerability handling and updates EUR 6,000 each

Two further figures frame the business case. The KONE-authored industrial study (2024, 12 companies, survey) found 50% expecting cost increases under 20%. LF 2026 found 47% of SME manufacturers expecting to raise prices to cover compliance (survey, 54 SME manufacturers).

Treat every figure above as a planning prompt, not a quote. Bitkom, Orgalim, DigitalEurope, ZVEI and techUK have published positions but no quantitative cost surveys that the research found.

KPIs

The programme board (Section 2) tracks these monthly; the executive review sees them quarterly. Every KPI reads from the system of record (Section 8) or the scope register (Section 4), never from a slide.

Metric	Target	Source of truth
Products with a recorded scope and class decision	100% of register rows by end of phase 1 (Dec 2026); 100% maintained	Scope register; decision records
Products with a conformity route and notified-body plan	100% of Class I and II rows by end of phase 1	Scope register
Risk assessments signed off by line 2	100% of Wave 1 by Feb 2027; 100% of in-scope products before placing on or after 11 Dec 2027	System of record, risk assessment status
Annex I applicability matrices with no blank justification	100% of signed assessments	System of record

Metric	Target	Source of truth
SBOM coverage per release	100% of releases with a signed SBOM meeting the TR-03183-2 fields; depth to the first out-of-scope component	Build pipeline; sbomqs results
Mean time to remediate by severity	Set per the vulnerability-handling policy; one vendor's example is 7 days critical, 30 days high, 90 days medium (CVD Portal, vendor); the CRA itself gives no numeric "without delay"	PSIRT case files
Upstream reports filed where due	100% of component vulnerabilities found, with duplicate-check recorded	PSIRT case files
Drill results against 24-hour and 72-hour targets	Two drills a year; early warning filed on paper within 24 hours by a deputy at a weekend; 72-hour content complete	Drill records
Awareness-to-early-warning time in live cases	Under 24 hours in 100% of cases; median tracked	PSIRT case files, UTC timeline
Technical files complete per Annex VII	100% of Wave 1 by Sep 2027; 100% before placing	System of record, file completeness check
Reasoned-request readiness	Test export of a complete file in under 10 working days, twice a year	Line 3 sampling
DoCs issued	One per family or product as planned, signed under the Section 2 instrument, before placing	DoC register
Supplier clauses in place	100% of suppliers of in-scope components under the Section 6 clauses or a documented exception	Procurement contract register
Supplier SBOMs received per release	100% of commercial components	Intake-gate records

Metric	Target	Source of truth
Open high-risk findings	Zero at any release gate; ageing of open findings reported	Risk register, product-risk category
Residual-risk acceptances and appeals	All recorded with a non-cost basis; appeals count reported	Product-risk register
Steward determinations and Art 24(1) policies	100% of published projects determined; policies published before 11 Dec 2027	Project registry
Training completion by role	100% of named roles before their first gate, drill or signature	Training records
Assigned Representative roster currency	Reviewed within 30 days of any personnel change; at least two active	Roster in the system of record
Standards and guidance review held	Quarterly, with a dated re-mapping decision	Review minutes

Board reporting cadence and content

The executive sponsor reports to the board quarterly, aligned with the executive review (Section 2). The report is short and reads from the KPIs.

1. Portfolio status: products in scope by class and wave; the share with a decision record, signed risk assessment, complete file and DoC.
2. The constraint: notified-body status for each Class I and II product, slot dates and the fallback.
3. Reporting performance: live cases and drills against the 24-hour and 72-hour targets; roster currency.
4. Risk: open high-risk findings, residual-risk acceptances and any appeal the sponsor decided.
5. Exposure: the Art 64 tiers, Member States with enforcement laws in force (three adopted on 30 Oct 2026; Germany awaiting promulgation), the PLD from 9 Dec 2026.
6. Money: spend against the budget lines above and any re-forecast.
7. Changes in the authority stack since the last report: FAQ or guidance versions, OJ citations, designations, delegated or implementing acts.
8. Decisions requested of the board, if any, with the written basis.

Keep the board aware that the authority stack is non-binding and moving. A board that signs off a programme built on a draft guidance version should know when that version changes.

Programme checklist

- [ ] Waves defined by class and revenue, with one representative product per family in Wave 1
- [ ] Phase 0 reporting readiness complete for the whole portfolio, legacy included
- [ ] Budget lines approved with benchmark labels retained in the papers
- [ ] KPIs wired to the system of record and the scope register, not to manual reporting
- [ ] Notified-body contracting milestone set for Q1 2027 with a fallback body
- [ ] Board report template agreed with the eight items above
- [ ] Wave review trigger set for any OJ citation, guidance version or designation

12. Corporate-level pitfalls

These failures happen at organisation level rather than in any one product, and each has a countermeasure elsewhere in this guide. Product-level pitfalls are in the knowledge base, Engineering compliance programme. Sources are consultancy or vendor observations unless an article or guidance paragraph is cited.

- Treating ISO/IEC 27001, IEC 62443 or EN 18031 certificates as CRA compliance (OmniTrust, consultancy). Countermeasure: map every certificate to Annex I with the gaps named; certificates feed the file, never replace it (Section 5).
- An ISMS scope that excludes firmware, build pipelines and update infrastructure (Clarysec, vendor). Countermeasure: rewrite the scope statement before any Module H plan, using BSI TR-03183-H clauses 4.2-4.3 (Section 5).
- Waiting for a cited harmonised standard or a designated notified body before building the file (cyberresilienceact.eu; Hogan Lovells, law firm). Countermeasure: complete Module A paperwork now and pre-contract two or three candidate bodies (Section 10).
- Residual product risk accepted on cost or appetite grounds, which guidance paras 156-163 call "not relevant". Countermeasure: a product-risk category in the enterprise framework with its own acceptance authority and a non-cost appeal rule (Sections 2, 5).
- No controlled authority for the DoC signature, so declarations are signed by whoever is asked. Countermeasure: a signing instrument, a pre-signature checklist and a counter-signature, logged per DoC (Section 2).

- Evidence scattered across ticketing, file shares, test tools and email, assembled by hand for each request (OmniTrust, consultancy). Countermeasure: one system of record fed by the release gate, with retention computed per version (Section 8).
- PSIRT and infrastructure CSIRT confused or combined, against BSI TR-03183-3's two-role requirement. Countermeasure: separate roles, mailboxes, keys and decision rights, joined by the multi-regime cell (Section 7).
- Legal review placed before the 24-hour early warning, delaying awareness pending approval (Wavect, vendor). Countermeasure: awareness authority with the PSIRT lead and deputies; legal on the 72-hour and final reports only (Sections 2, 7).
- Undercounted inventory missing versions, OEM units, companion apps and cloud functions, often by five-fold (OmniTrust, consultancy). Countermeasure: build the register from release and commercial systems with change triggers, and plan a second reconciliation (Section 4).
- Supplier contracts without vulnerability-notification, SBOM or disclosure clauses, and passive reliance on upstream fixes by 51% of manufacturers (Clarysec, vendor; LF 2026, survey). Countermeasure: the ten clauses and the questionnaire in master agreements, with refusals routed to the intake gate (Section 6).
- Publishing open source without a steward or manufacturer determination, so Art 24(1) duties land unplanned or monetisation quietly creates a manufacturer. Countermeasure: a per-project determination memo owned by legal and a published Art 24(1) policy for every stewarded project (Section 6).
- UK teams assuming UKCA Approved Bodies can act as CRA notified bodies, or that Northern Ireland is already covered. Countermeasure: budget for an EU notified body and an authorised representative, and review the Windsor Framework position quarterly (Section 10).